



МИНОБРНАУКИ РОССИИ
Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА – Российский технологический университет»
РТУ МИРЭА
Колледж программирования и кибербезопасности

ДИПЛОМНЫЙ ПРОЕКТ

СПЕЦИАЛЬНОСТЬ 10.02.04
Обеспечение информационной безопасности телекоммуникационных систем

на тему:

**«Настройка политики фильтрации трафика с использованием
межсетевого экрана открытого исходного кода»**

Выполнил студент
группы ЩТКО-01-22

Макасеев М.А.
подпись ФИО студента

Руководитель
Журавлёва В.С.
подпись ФИО руководителя

Нормоконтроль
Герасин В.Ю.
подпись ФИО руководителя

Москва 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ	4
1 АНАЛИЗ ОБЪЕКТА ЗАЩИТЫ И НОРМАТИВНО-ПРАВОВЫХ ТРЕБОВАНИЙ В ОБЛАСТИ ОБЕСПЕЧЕНИЯ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ.....	6
1.1 Исследование объекта защиты	6
1.2 Анализ нормативно-правовой базы.....	8
1.3 Техническая оснащенность организации	10
1.4 Модель угроз информационной безопасности	13
2 АНАЛИЗ И ВЫБОР МЕЖСЕТЕВЫХ ЭКРАНОВ	17
2.1 Назначение и классификация межсетевого экрана	17
2.2 Выбор программного решения для реализации межсетевого экрана	18
3 ПРАКТИЧЕСКАЯ РЕАЛИЗАЦИЯ И ОБЕСПЕЧЕНИЕ СЕТЕВОЙ БЕЗОПАСНОСТИ.....	21
3.1 Анализ уязвимостей сетевой инфраструктуры.....	21
3.2 Установка и базовая настройка	23
3.3 Реализация политики фильтрации трафика и устранение выявленных уязвимостей	31
ЗАКЛЮЧЕНИЕ	46
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ	48

ПЕРЕЧЕНЬ СОКРАЩЕНИЙ И ИСПОЛЬЗОВАННЫХ ОБОЗНАЧЕНИЙ

АРМ	—	автоматизированное рабочее место.
ВМ	—	виртуальная машина.
ИСПДн	—	информационная система персональных данных.
ИТ	—	информационные технологии.
МЭ	—	межсетевой экран.
ОС	—	операционная система.
ООО	—	общество с ограниченной ответственностью
СЗИ	—	средство защиты информации.
СУБД	—	система управления базами данных.
ХОП	—	один шаг, который совершает пакет данных при передаче от источника к пункту назначения.
BGP	—	(англ. Border Gateway Protocol) протокол динамической маршрутизации.
CPU	—	(англ. Central Processing Unit) центральный процессор.
DoS	—	(англ. Denial-of-Service attack) отказ в обслуживании.
DDoS	—	(англ. Distributed Denial-of-Service attack) распределённый отказ в обслуживании.
DNS	—	(англ. Domain Name System) система доменных имён.
DHCP	—	(англ. Dynamic Host Configuration Protocol) протокол, позволяющий устройствам автоматически получать IP-адрес.
FTP	—	(англ. File Transfer Protocol) протокол для передачи файлов между клиентом и сервером.
GUI	—	(англ. Graphical User Interface) графический пользовательский интерфейс.

HTTP	–	(англ. HyperText Transfer Protocol) протокол для передачи данных между клиентом и сервером.
HTTPS	–	(англ. HyperText Transfer Protocol Secure) протокол для обеспечения конфиденциальности и целостности данных между клиентом и сервером.
ICMP	–	(англ. Internet Control Message Protocol) протокол межсетевых управляющих сообщений.
IDS	–	(англ. Intrusion Detection System) система обнаружения вторжений.
IPS	–	(англ. Intrusion Prevention System) система предотвращения вторжений.
LAN	–	(англ. Local Area Network) локальная компьютерная сеть.
MITM	–	(англ. Man-in-The-Middle) тип кибератаки, при которой злоумышленник тайно вклинивается в канал связи между двумя участниками.
NAT	–	(англ. Network Address Translation) технология трансляции сетевых адресов.
NGFW	–	(англ. Next Generation Firewalls) межсетевой экран нового поколения.
NTP	–	(англ. Network Time Protocol) протокол для синхронизации внутренних часов.
OSPF	–	(англ. Open Shortest Path First) протокол динамической маршрутизации для поиска кратчайшего пути в компьютерной сети.
OSI	–	(англ. Open System Interconnection) 7-уровневая эталонная модель взаимодействия сетевых устройств.
QoS	–	(англ. Quality of Service) качество обслуживания.

SNMP	–	(англ. Simple Network Manager Protocol) протокол для мониторинга и управления сетевыми устройствами.
STP	–	(англ. Spanning Tree Protocol) протокол, автоматически предотвращающий логические петли в компьютерных сетях.
TLS	–	(англ. Transport Layer Security) криптографический протокол, обеспечивающий безопасную передачу данных в интернете между клиентом и сервером.
TCP	–	(Transmission Control Protocol) протокол передачи данных с установлением соединения.
UDP	–	(англ. User Datagram Protocol) протокол передачи данных без установления соединения.
USB	–	(англ. Universal Serial Bus) универсальная последовательная шина.
VPN	–	(англ. Virtual Private Network) виртуальная компьютерная частная сеть.
VRRR	–	(англ. Virtual Router Redundancy Protocol) протокол резервирования виртуального маршрутизатора.
VLAN	–	(англ. Virtual Local Area Network) виртуальная локальная компьютерная сеть.
WAN	–	(англ. Wide Area Network) глобальная вычислительная компьютерная сеть.
XSS	–	(англ. Cross-Site Scripting) межсайтовый скриптинг.
ZFS	–	(англ. Zettabyte File System) 128-битовая файловая система с открытым исходным кодом.

ВВЕДЕНИЕ

Развитие цифровых технологий и повсеместное подключение к глобальным сетям привели к резкому увеличению объёмов передаваемой информации и росту числа потенциальных угроз. В этих условиях обеспечение информационной безопасности (далее – ИБ) становится одной из приоритетных задач для организаций, использующих автоматизированные информационные системы. Одним из важнейших элементов защиты корпоративных сетей является грамотное управление сетевым трафиком и предотвращение несанкционированного доступа, что достигается путём внедрения и настройки межсетевых экранов.

Межсетевые экраны, как ключевые компоненты периметровой защиты, обеспечивают контроль входящего и исходящего сетевого трафика на основе заранее заданных правил. Грамотно разработанная политика фильтрации позволяет эффективно блокировать вредоносную активность, ограничивать доступ к критическим ресурсам и минимизировать риск сетевых атак.

Целью проекта является разработка и внедрение политики фильтрации трафика, обеспечивающей базовую защиту корпоративной сети от внешних и внутренних угроз с использованием программного межсетевого экрана.

Для достижения поставленной цели необходимо решить следующие задачи:

- изучить нормативно-правовую базу в области обеспечения информационной безопасности;
- изучить принципы работы межсетевых экранов и подходы к фильтрации трафика;
- проанализировать текущую сетевую инфраструктуру организации;
- определить потенциальные угрозы и риски, связанные с сетевыми подключениями;
- разработать политику фильтрации трафика, соответствующую

требованиям безопасности;

- внедрить и протестировать правила фильтрации на выбранной платформе.

Реализация дипломного проекта позволит обеспечить требуемый уровень сетевой безопасности при помощи применения межсетевых экранов в условиях ограниченных ресурсов.

1 АНАЛИЗ ОБЪЕКТА ЗАЩИТЫ И НОРМАТИВНО-ПРАВОВЫХ ТРЕБОВАНИЙ В ОБЛАСТИ ОБЕСПЕЧЕНИЯ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

1.1 Исследование объекта защиты

Полное наименование организации: общество с ограниченной ответственностью «Авангард Бюро» (далее – ООО «Авангард Бюро»).

ООО «Авангард Бюро» – частная организация, специализирующаяся на комплексном бухгалтерском и юридическом сопровождении хозяйственной деятельности юридических лиц и индивидуальных предпринимателей.

Организация предоставляет услуги бухгалтерского аутсорсинга (ведение бухгалтерии «под ключ»), включая обработку первичных документов, учет хозяйственных операций, формирование финансовой отчетности и консультационное сопровождение по вопросам налогообложения и учета. Также ООО «Авангард Бюро» оказывает юридическое сопровождение: подготовку договоров, консультирование по правовым вопросам, правовую поддержку в рамках договорных отношений, помощь при взаимодействии с контролирующими органами и судебными инстанциями.

Услуги компании направлены на обеспечение качественного бухгалтерского и правового обслуживания бизнес-клиентов, защиты их интересов в сфере финансового и корпоративного права, сокращение рисков ошибок в отчетности и повышению эффективности управления финансовыми потоками.

Организация «Авангард Бюро» не относится к государственным учреждениям, не выполняет функции государственных или муниципальных органов и не входит в перечень субъектов, отнесенных к критической информационной инфраструктуре Российской Федерации.

В Приложении 1 отображена схема организационной структуры и информационных потоков ООО «Авангард Бюро».

Главой организации является генеральный директор, которому подчиняются руководители ключевых направлений.

Отдел информационной безопасности и технический отдел находятся в ведении технического директора, что обеспечивает их тесную интеграцию в общую архитектуру ИТ-инфраструктуры организации. В составе отдела информационной безопасности работают 5 специалистов, каждый из которых отвечает за отдельное направление: разработку политик, настройку межсетевых экранов, анализ журналов событий, аудит конфигураций и проверку уязвимостей. Помимо отдела информационной безопасности в организации существуют и другие:

- бухгалтерский отдел занимается ведением бухгалтерского и налогового учёта клиентов на условиях аутсорсинга, обработкой первичной документации, расчётом налогов и обязательных платежей, формированием отчётности и взаимодействием с контролирующими органами [14];

- юридический отдел обеспечивает правовое сопровождение деятельности клиентов: разрабатывает и проводит экспертизу договоров, консультирует по вопросам корпоративного, гражданского и налогового права, представляет интересы клиентов в государственных органах и участвует в судебной работе [15];

- финансово-аналитический отдел отвечает за финансовое планирование и анализ хозяйственной деятельности клиентов, готовит управленческую отчётность, оценивает налоговую нагрузку и консультирует по вопросам оптимизации финансовых процессов [16];

- отдел по работе с клиентами организует взаимодействие с клиентами, сопровождает договоры на оказание услуг, координирует передачу документов, консультирует по вопросам обслуживания и контролирует качество предоставляемых услуг.

Персональные данные абонентов и сотрудников организации передаются по нескольким типам каналов, включая внутренние API,

защищённые соединения, такие как Virtual Private Network (далее – VPN), а также веб-интерфейсы с обязательной авторизацией. В ряде случаев осуществляется интеграция с внешними сервисами, например, платёжными системами, что требует дополнительных мер защиты.

Данные шифруются при передаче и хранении, доступ разграничивается по ролям, все действия журналируются. Коммерческая информация передаётся по корпоративным сетям, электронной почте и системам электронного документооборота, а при взаимодействии с внешними сторонами – только по зашифрованным каналам в рамках NDA.

Внутренняя техническая информация передаётся через изолированные административные сети и защищённые VPN, обрабатывается через специализированные ИТ-платформы. Доступ защищён двухфакторной аутентификацией и строгим контролем прав, все действия администраторов фиксируются, резервные копии регулярно создаются и проверяются [17].

1.2 Анализ нормативно-правовой базы

В процессе разработки и внедрения политики фильтрации трафика с использованием межсетевого экрана в организации необходимо опираться на следующие нормативно-правовые акты в области информационной безопасности:

- Федеральный закон «Об информации, информационных технологиях и о защите информации» от 27.07.2006 № 149-ФЗ. Закон определяет основы государственной политики в области информационной безопасности, включая обязанности по защите информации от несанкционированного доступа и нарушения её целостности при передаче по сетям связи [1];

- Федеральный закон «О персональных данных» от 27.07.2006 № 152-ФЗ. Устанавливает порядок обработки, хранения и защиты персональных данных, передаваемых через сеть, включая требования к реализации мер

защиты в сетевой инфраструктуре с использованием межсетевых экранов и фильтрации трафика [2];

– Указ Президента РФ от 5 декабря 2016 г. № 646 «Об утверждении Доктрины информационной безопасности Российской Федерации». Документ формирует стратегические направления и задачи в области ИБ, включая защиту информационной инфраструктуры от сетевых угроз, где ключевую роль играют технологии фильтрации и межсетевые экраны [3];

– Постановление Правительства РФ от 1 ноября 2012 г. № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных». Устанавливает уровни защищённости и требования к организации технической защиты, включая необходимость применения межсетевых экранов с соответствующей политикой фильтрации [4];

– ГОСТ ИСО/МЭК 27001-2021 «Информационные технологии. Методы и средства обеспечения безопасности». Стандарт регулирует разработку политики информационной безопасности, включая управление доступом, анализ рисков, построение архитектуры защиты с применением межсетевых экранов [5];

– Методический документ ФСТЭК «Методика оценки угроз безопасности информации». Описывает подходы к построению модели угроз, на основании которых разрабатываются правила фильтрации трафика и политика доступа в организации [6];

– Приказ ФСТЭК России от 11 апреля 2025 г. № 117 «Об утверждении требований о защите информации, не составляющей государственную тайну». Уточняет обязательные меры защиты информации в государственных ИС, включая средства сетевой фильтрации, контроль доступа и разграничение прав [7];

– Приказ ФСТЭК России от 18 февраля 2013 г. № 21 «Об утверждении состава и содержания организационных и технических мер по

обеспечению безопасности персональных данных». Определяет требования к применению технических средств защиты, в том числе межсетевых экранов, и разработке политики сетевого трафика в информационных системах [8];

- ГОСТ Р 50739-95 «Средства вычислительной техники. Защита от несанкционированного доступа к информации. Общие технические требования». Устанавливает технические требования к реализации сетевой защиты, включая фильтрацию и разграничение доступа [9];

- Руководящий документ Гостехкомиссии при Президенте РФ от 4 июня 1999 г. № 114. Уточняет классификацию и проверку программных средств защиты от недекларированных возможностей, в том числе межсетевых экранов, участвующих в фильтрации сетевого трафика [10].

На основании перечисленных нормативно-правовых актов осуществляется анализ требований к защите информации, выбор средств фильтрации трафика и построение политики безопасности, соответствующей установленным стандартам и рекомендациям.

1.3 Техническая оснащенность организации

Внедрение межсетевого экрана (далее – МЭ) pfSense осуществляется в корпоративной сети головного офиса, в состав которой входит:

- центральный маршрутизатор Zyxel USG Flex [18];
- серверная стойка с файловыми и базовыми сервисами (AD, DHCP, DNS, почта, внутренние приложения);
- резервный шлюз и точку выхода в интернет с резервированием по технологии BGP;
- VLAN-сегментация сети: отдельно для разработчиков, бухгалтерии, общего офиса, Wi-Fi для гостей;
- VPN-шлюз для защищённого доступа сотрудников из других регионов;
- система централизованного логирования и аудита (Syslog и ELK-стек) [19];

– система мониторинга состояния инфраструктуры (Zabbix) [20].

Все рабочие станции сотрудников защищены средствами антивирусной защиты с централизованным управлением, а доступ к критически важным данным ограничен и регламентирован внутренними политиками безопасности [21].

Высокопроизводительное техническое оснащение обеспечивает эффективную, стабильную и безопасную работу организации. Немалое количество организаций пренебрегает функциональным состоянием автоматизированных рабочих мест (далее – АРМ), серверного и сетевого оборудования. Большой проблемой в том числе является недостаточная осведомленность рядовых сотрудников о порядке обращения с программным обеспечением и в вопросах поддержания уровня безопасности корпоративных данных, устаревшее вычислительное оборудование. Это еще раз подчеркивает необходимость интеграции системы мониторинга для оперативного отслеживания состояния функциональных единиц информационной инфраструктуры организации. Для обеспечения полноценного мониторинга цифровых активов следует выделить технические особенности оборудования. Типовая конфигурация АРМ сотрудника организации приведена в таблице 1.

Таблица 1 – Типовая конфигурация АРМ сотрудника организации

Характеристика	Значение
Процессор	Intel® Core™ i5-10400
Материнская плата	GIGABYTE H410M H V2
Корпус	DEERCOOL MATREXX 50
Видеокарта	Отсутствует, процессор имеет встроенное графическое ядро
Оперативная память	Patriot Signature Line Premium 8Gb
Накопитель	250Gb SSD M2 Crucial P2
Блок питания	Cougar VTE400
Операционная система	Astra Linux Common Edition 2.12

В организации имеется серверное помещение, содержащее в себе несколько мощных серверов, отведенных под определенные задачи. Имеется также сервер виртуализации для размещения программных комплексов, не

требующих высоких вычислительных мощностей. Решение позволяет эффективно распределять ресурсы и снижать затраты на обслуживание. Именно на этом сервере планируется интеграция серверной части системы мониторинга. Характеристики сервера виртуализации представлены в таблице 2.

Таблица 2 – Характеристики сервера виртуализации

Характеристика	Значение
Процессор	Intel® Core™ i7-14700K
Материнская плата	MSI PRO B760-P DDR4 II
Видеокарта	Отсутствует
Корпус	DEEPCOOL CH370
Оперативная память	Patriot Viper Elite II 64Gb
Накопители	2Tb NVMe M2 Samsung 960 EVO x2
	2Tb HDD Seagate SkyHawk x2
Блок питания	Be Quiet SYSTEM POWER 9 700W
Операционная система	Proxmox VE 8.4

Сетевая инфраструктура организации построена по классической схеме с разделением на внутреннюю (англ. Local Area Network далее – LAN) и внешнюю (англ. Wide Area Network далее – WAN) зоны. Центральными элементами являются маршрутизаторы уровня ядра, обеспечивающие связь локальной сети с провайдерами через защищённый пограничный МЭ. Все входящие и исходящие соединения фильтруются согласно Политике информационной безопасности ООО «Авангард Бюро», утвержденной Приказом директора от 25 марта 2025 г. «О введении в действие локальных актов».

Сетевая инфраструктура предприятия представлена в Приложении 2.

Во внутреннем сегменте используются управляемые коммутаторы уровней 2 и 3, которые обеспечивают коммутацию рабочих станций, серверов и иных сетевых устройств. Сеть сегментирована с помощью VLAN для разделения рабочих групп и критически важных сервисов. В серверной установлены резервируемые коммутаторы и источники бесперебойного питания.

Для удалённого доступа сотрудников используется VPN-подключение через пограничный МЭ с аутентификацией и шифрованием трафика. Также реализовано дублированное подключение к интернет-провайдеру с использованием протокола VRRP для повышения отказоустойчивости.

Два устройства MikroTik CCR1009 выполняют роль пограничных роутеров и используются для маршрутизации трафика между сегментами сети и интернетом. Маршрутизаторы имеют девять портов Gigabit Ethernet, поддержку VPN, NAT, QoS, OSPF, BGP и VRRP.

Для коммутации пакетов данных внутри VLAN используется коммутатор уровня 3 Cisco Catalyst 2960-X. Основные характеристики: 24 порта, среди которых 20 Fast Ethernet и 4 Gigabit Ethernet, поддержка VLAN, SNMP и STP.

Неуправляемые коммутаторы уровня 2 D-Link DGS-1210-28 используются для коммутации кадров между рабочими станциями и сетевыми принтерами. Каждое устройство имеет 5 Fast Ethernet портов.

Источник бесперебойного питания APC Smart-UPS 1500VA используется для резервного питания серверной и оборудования. Основные характеристики включают в себя автоматическую регулировку напряжения, интерфейсы USB и Serial, а также возможность управления по сети.

Имеющаяся техническая база предприятия позволяет в полной мере реализовать задачи дипломного проекта.

1.4 Модель угроз информационной безопасности

Согласно составленной модели, представленной в Приложении 3, к актуальным угрозам относятся следующие:

– ошибки конфигурации правил фильтрации – некорректная настройка NAT или разрешающих правил на WAN, приводящая к доступности внутренних сервисов извне и возможности несанкционированного подключения;

- сканирование и подбор открытых портов – преднамеренное использование средств анализа сети (nmap, masscan) для выявления доступных сервисов и подготовки атак на внутренние ресурсы;
- атаки через зашифрованный HTTPS трафик – внедрение вредоносных нагрузок в TLS сессии при отсутствии или некорректной реализации SSL/TLS инспекции, что исключает возможность анализа содержимого и позволяет обходить механизмы фильтрации;
- DoS/DDoS атаки на WAN интерфейс – генерация большого объёма TCP/UDP трафика, приводящая к перегрузке ресурсов pfSense и отказу в обслуживании легитимных пользователей;
- эксплуатация уязвимостей программного обеспечения pfSense – использование известных (CVE) или «zero day» уязвимостей в программной реализации межсетевого экрана для получения несанкционированного доступа, повышения привилегий или вывода системы из строя;
- модификация журналов межсетевого экрана – несанкционированное изменение или удаление записей логирования с целью сокрытия следов атаки и искажения результатов расследования инцидента.

Действия внутреннего нарушителя – преднамеренное изменение правил фильтрации или снятие ограничений администратором, обладающим избыточными правами доступа, что ослабляет защиту сети и открывает возможность внешних атак.

Внешний нарушитель – это физическое лицо, не обладающее легитимным доступом к внутренним ресурсам организации, но имеющее мотивацию нанести вред. В некоторых случаях угрозу для информационной безопасности могут представлять бывшие сотрудники организации. Несмотря на отсутствие глубоких технических знаний, они сохраняют определённое понимание структуры сети и особенностей её работы. К этой же категории относятся мелкие злоумышленники, действующие из корыстных побуждений и стремящиеся получить выгоду за счёт

компрометации данных или вымогательства. Такие нарушители используют простые и доступные методы, не требующие серьёзной подготовки. На практике это выражается в применении элементарных форм фишинга, например, рассылки писем с вредоносными вложениями, подборе слабых паролей к учётным записям, попытках доступа через открытые порты или эксплуатации уязвимостей веб-интерфейсов. Для реализации подобных действий они прибегают к готовым скриптам, утилитам и онлайн-сервисам, свободно распространяемым в сети. Поэтому при разработке политики фильтрации трафика на базе pfSense необходимо учитывать данный класс угроз и предусматривать меры, направленные на блокировку несанкционированного доступа и снижение рисков, связанных с использованием простых, но потенциально эффективных техник атак.

Внутренний нарушитель – это сотрудник или студент организации, обладающий ограниченным, но легитимным доступом к внутренним ресурсам. Мотивация внутренних нарушителей может быть связана с недовольством, стремлением к личной выгоде или случайными действиями, обусловленными низким уровнем осведомлённости в области информационной безопасности. Подобные лица способны осуществлять кражу учётных данных, вносить изменения в информационные системы или получать несанкционированный доступ к конфиденциальным файлам. Наибольшему риску подвергаются базы данных, файловые хранилища, электронные образовательные платформы и учётные записи сотрудников. Последствия деятельности внутреннего нарушителя выражаются в утечке или искажении данных, саботаже учебных процессов и снижении доверия к информационным системам [23].

В рамках разработки политики фильтрации трафика на базе pfSense необходимо учитывать данный тип угроз и предусматривать меры, направленные на предотвращение подобных инцидентов и минимизацию их последствий.

Инсайдер – это сотрудник, обладающий расширенными административными правами (сотрудники отдела информационных технологий, руководители структурных подразделений). Этот тип нарушителя представляет наибольшую опасность, поскольку обладает доступом к ключевым элементам инфраструктуры. Его действия могут быть связаны со злоупотреблением служебным положением, халатностью или преднамеренными вредоносными поступками. В качестве методов атаки могут использоваться отключение систем мониторинга, удаление журналов событий, изменение конфигураций сетевого оборудования, а также некорректная настройка средств защиты информации (СЗИ). Последствия таких действий выражаются в сокрытии инцидентов, нарушении функционирования сети и блокировке доступа к критически важным ресурсам [24].

При разработке политики фильтрации трафика на базе pfSense необходимо учитывать угрозы, исходящие от внутренних пользователей с расширенными правами, и предусматривать меры, направленные на предотвращение злоупотреблений и обеспечение контроля за их активностью.

Преступные хакерские группировки относятся к категории высококвалифицированных нарушителей. Их целью может быть проведение целенаправленных атак на образовательные учреждения для сбора конфиденциальной информации, подготовки к более масштабным операциям или вмешательства в образовательные процессы. В арсенал таких атакующих входят целевой фишинг, использование эксплойтов нулевого дня, многоуровневые атаки и перемещение внутри сети. Наибольшему риску подвергаются критические серверы, обрабатывающие персональные данные, межсетевые экраны и системы аутентификации. Последствия подобных атак выражаются в длительном скрытом присутствии злоумышленников в инфраструктуре, массовой утечке данных и компрометации ключевых систем безопасности.

2 АНАЛИЗ И ВЫБОР МЕЖСЕТЕВЫХ ЭКРАНОВ

2.1 Назначение и классификация межсетевого экрана

МЭ – это программно-аппаратный или программный комплекс, предназначенный для фильтрации сетевого трафика на основе заранее заданных правил. Он осуществляет анализ входящих и исходящих сетевых пакетов, принимая решение о пропуске, блокировке, перенаправлении или преобразовании пакета. Основной задачей межсетевого экрана является защита периметра организации, то есть границы между внутренней (доверенной) и внешней (недоверенной) сетевой средой, включая сеть интернет, а также контроль взаимодействий между сегментами внутри корпоративной сети.

Система фильтрации трафика и межсетевого экранирования является неотъемлемым элементом информационной безопасности организации. Она обеспечивает предотвращение несанкционированного доступа к внутренним ресурсам организации, защиту от сетевых атак, контроль за входящими и исходящими соединениями, а также выполнение политик безопасности.

Существует несколько классификаций межсетевых экранов, основанных на различных признаках. Наиболее распространённой является классификация по уровню модели OSI, на котором осуществляется фильтрация:

- сетевые (пакетные) экраны – работают на сетевом и транспортном уровнях, анализируя заголовки IP-пакетов. Такие экраны обеспечивают базовую фильтрацию, не отслеживая состояние соединений;
- межсетевые экраны с отслеживанием состояния (stateful firewalls)
 - помимо анализа заголовков пакетов, сохраняют контекст сеансов и могут принимать решения на основе состояния соединений. Это позволяет более эффективно обнаруживать аномальную активность;
- прикладные (прокси) экраны – функционируют на прикладном уровне модели OSI, обеспечивая глубокий анализ содержимого трафика.

Такие экраны способны фильтровать данные по содержимому приложений и протоколов (HTTP, FTP и др.), предоставляя высокий уровень защиты;

- межсетевые экраны нового поколения (Next Generation Firewalls, NGFW) – совмещают функции stateful firewall, IDS/IPS (систем обнаружения и предотвращения вторжений), а также обладают возможностями для инспекции зашифрованного трафика, анализа приложений и управления политиками на уровне пользователей.

2.2 Выбор программного решения для реализации межсетевого экрана

В соответствии с техническим заданием от руководства ООО «Авангард Бюро», основной задачей является выбор программного решения с функциями межсетевого экранирования, подходящего для развертывания в существующей ИТ-инфраструктуре. Особое внимание при этом уделяется критериям отказоустойчивости, удобства администрирования, гибкости настройки правил и совместимости с существующими программно-аппаратными компонентами.

В ходе анализа рассмотрены три программных продукта с открытым исходным кодом с функцией межсетевого экранирования:

- pfSense;
- OPNsense;
- Kerio Control.

Все они обладают широким спектром функций и способны обеспечить базовую и продвинутую фильтрацию трафика.

Проект pfSense – это бесплатный дистрибутив FreeBSD с открытым исходным кодом, специально разработанный для использования в качестве брандмауэра и маршрутизатора, полностью управляемый простым в использовании веб-интерфейсом. Этот веб-интерфейс известен как веб-конфигуратор GUI, или сокращенно WebGUI. Для развертывания и использования программного обеспечения pfSense не требуется никаких знаний FreeBSD. Фактически, большинство пользователей никогда не

использовали FreeBSD вне программного обеспечения pfSense. Программное обеспечение pfSense включает в себя длинный список связанных функций. Система пакетов программного обеспечения pfSense обеспечивает возможность дальнейшего расширения без добавления раздувания и потенциальных уязвимостей безопасности в базовый дистрибутив.

OPNsense – это клон pfSense, обладающий схожей функциональностью, но отличающийся улучшенным пользовательским интерфейсом, упрощённым управлением и дополнительными модулями безопасности. OPNsense также поддерживает IDS/IPS, VPN, прокси-сервер, двухфакторную аутентификацию, а также интеграцию с внешними системами мониторинга. К преимуществам можно отнести частые обновления, стабильную работу на виртуальных платформах и наличие встроенных отчётов по событиям безопасности. Тем не менее, OPNsense требует больше ресурсов в сравнении с pfSense и может быть менее предсказуем при нестандартной конфигурации.

Kerio Control – это коммерческий продукт с удобным веб-интерфейсом, разработанный для малых и средних организаций. Он предоставляет функции firewall, VPN, антивирусной фильтрации, управления полосой пропускания и ведения подробных журналов. Kerio Control отличается простотой внедрения и сопровождения, однако ограничен в возможностях кастомизации и требует приобретения лицензии, что может быть сдерживающим фактором для организации, ориентированной на экономию бюджета. Сравнительные характеристики программных продуктов представлены в таблице 3.

Таблица 3 – Сравнительные характеристики программных продуктов

Характеристика	pfSense	OPNsense	Kerio Control
Тип лицензии	Open Source	Open Source	Коммерческая
Поддержка VPN	Да (OpenVPN, IPsec)	Да (OpenVPN, IPsec)	Да
IDS/IPS	Да (Snort, Suricata)	Да (встроено)	Ограничено
Веб-интерфейс	Есть	Улучшенный	Интуитивный

Таблица 3 – Продолжение

Характеристика	pfSense	OPNsense	Kerio Control
Масштабируемость	Высокая	Средняя	Низкая
Ресурсоёмкость	Низкая	Средняя	Средняя
Поддержка плагинов	Широкая	Средняя	Отсутствует

На основании проведённого анализа, в качестве основного программного продукта для реализации политики фильтрации трафика в ООО «Авангард Бюро» выбрана система pfSense. Она сочетает в себе высокую степень надёжности, расширяемость, поддержку современных стандартов безопасности и удобный интерфейс управления. Благодаря открытому исходному коду и большому сообществу, pfSense предоставляет возможность тонкой настройки под нужды организации, не требуя при этом дополнительных затрат на лицензирование. Интеграция pfSense в корпоративную сеть организации позволит не только эффективно реализовать требования по контролю и защите трафика – такие как фильтрация пакетов на основе политик безопасности, разграничение доступа между сетевыми сегментами, предотвращение несанкционированных подключений, мониторинг активности пользователей и выявление сетевых аномалий с использованием IDS/IPS, а также контроль использования сетевых ресурсов и журналирование событий, но и обеспечит основу для реализации дальнейших задач дипломного проекта.

3 ПРАКТИЧЕСКАЯ РЕАЛИЗАЦИЯ И ОБЕСПЕЧЕНИЕ СЕТЕВОЙ БЕЗОПАСНОСТИ

3.1 Анализ уязвимостей сетевой инфраструктуры

В ходе анализа сетевой инфраструктуры ООО «Авангард Бюро» были выявлены уязвимости, оказывающие существенное влияние на уровень защищённости корпоративной сети. Их наличие обусловлено особенностями текущей архитектуры, а также отсутствием централизованного механизма контроля сетевого трафика. Для обеспечения требуемого уровня безопасности необходимо внедрение межсетевого экрана, способного фильтровать входящие и исходящие соединения, разграничивать доступ между сегментами сети и предотвращать эксплуатацию уязвимостей. На основании проведённого обследования выделены три ключевые уязвимости, требующие устранения.

Первая уязвимость связана с отсутствием сегментации внутренней сети. В существующей архитектуре рабочие станции, серверы и вспомогательные устройства находятся в едином широковещательном домене, что фактически формирует единую зону доверия. Такое построение сети приводит к тому, что любое устройство получает возможность прямого взаимодействия с критически важными ресурсами. Отсутствие VLAN-разделения и межсетевых политик создаёт условия для горизонтального перемещения злоумышленника в случае компрометации одного из узлов. Кроме того, повышается вероятность перехвата трафика, проведения атак типа ARP-spoofing и MITM, а также распространения вредоносного программного обеспечения. Для устранения данной уязвимости требуется внедрение межсетевого экрана, обеспечивающего фильтрацию трафика между сегментами и контроль межсетевого взаимодействия.

Вторая уязвимость заключается в доступности внутренних сервисов из внешней сети. В ходе анализа было выявлено, что ряд сервисов, включая

административные панели и служебные веб-интерфейсы, доступны напрямую из сети провайдера. Это создаёт угрозу несанкционированного доступа, брутфорс-атак и эксплуатации известных уязвимостей. Причинами возникновения данной проблемы являются отсутствие фильтрации входящего трафика на периметре, некорректная настройка NAT и отсутствие централизованной политики блокировки внешних подключений. В случае успешной атаки злоумышленник может получить доступ к внутренним ресурсам, что создаёт риск компрометации серверов, утечки конфиденциальной информации и нарушения целостности данных. Для устранения данной уязвимости необходимо внедрение межсетевого экрана, способного контролировать входящие соединения и ограничивать доступ к внутренним сервисам.

Третья уязвимость относится к внутреннему веб-приложению организации и связана с возможностью проведения атаки типа межсайтового скриптинга (XSS). Веб-форма, используемая сотрудниками, не осуществляет корректную фильтрацию пользовательского ввода, что позволяет внедрять вредоносный JavaScript-код. Несмотря на то, что XSS является уязвимостью уровня приложения, её последствия напрямую затрагивают сетевую инфраструктуру. Вредоносный скрипт может осуществлять кражу «cookie» и токенов авторизации, выполнять произвольный JavaScript-код, загружать внешние скрипты с вредоносных доменов, а также инициировать обращения к управляющим серверам злоумышленника. Кроме того, через браузер пользователя возможны попытки сканирования внутренних ресурсов.

Для устранения выявленных уязвимостей и реализации централизованной политики фильтрации трафика межсетевой экран pfSense устанавливается на границе сети, между внутренним сегментом (LAN) и внешней сетью провайдера (WAN). Такое размещение позволяет контролировать все входящие и исходящие соединения, блокировать несанкционированные подключения извне, ограничивать доступ к критически важным ресурсам и предотвращать загрузку вредоносных

скриптов. Установка pfSense на периметре обеспечивает единый механизм контроля трафика и позволяет эффективно снизить риски, связанные с отсутствием сегментации, доступностью внутренних сервисов из внешней сети и возможностью эксплуатации XSS-уязвимостей [22].

3.2 Установка и базовая настройка

На основании результатов анализа уязвимостей сетевой инфраструктуры и определения оптимальной точки размещения межсетевого экрана pfSense производится его установка и выполнение первичной конфигурации.

На данном этапе осуществляется развёртывание программного решения, настройка сетевых интерфейсов и подготовка системы к реализации политики фильтрации трафика, направленной на устранение выявленных угроз.

Для установки системы pfSense из образа необходимо создать виртуальную машину (далее – VM).

Характеристики VM:

- процессоры: 2;
- оперативная память: 4096;
- количество сетевых адаптеров: 2.

После создания VM производится установка системы pfSense. Приветственный экран загрузчика представлен на рисунке 1.

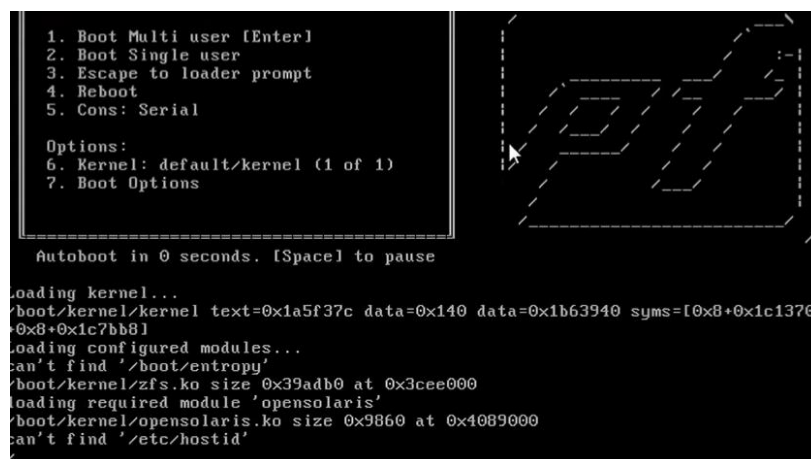


Рисунок 1 – Приветственный экран загрузчика

Запрос установки системы pfSense представлен на рисунке 2.

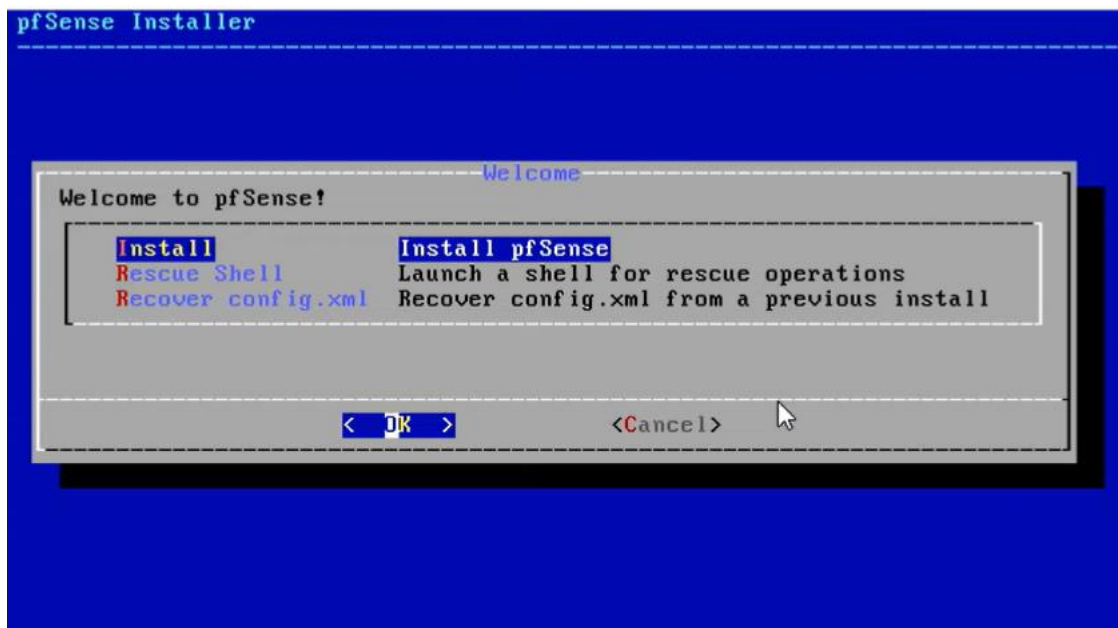


Рисунок 2 – Запрос установки системы pfSense

Предварительные настройки установки системы pfSense представлены на рисунке 3.



Рисунок 3 – Предварительные настройки системы pfSense

Система pfSense предлагает использовать зеркальный жёсткий диск. В случае отказа одного из них, оставшийся продолжает работать, обеспечивая работоспособность системы. Запрос системы pfSense на распределение жёстких дисков представлен на рисунке 4.

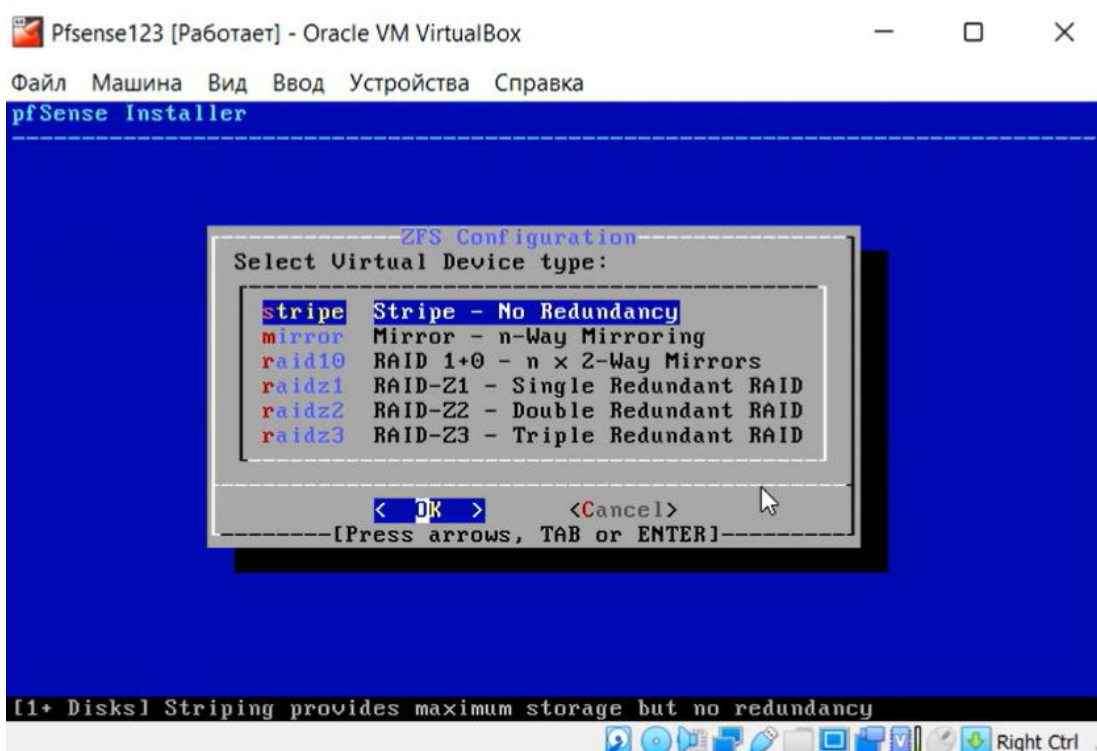


Рисунок 4 – Запрос системы pfSense на распределение жёстких дисков

Система pfSense предупреждает, что жёсткие диски, находящиеся под управлением системы, отформатированы. Так как система pfSense использует файловую систему ZFS. Предупреждение системы pfSense представлено на рисунке 5.

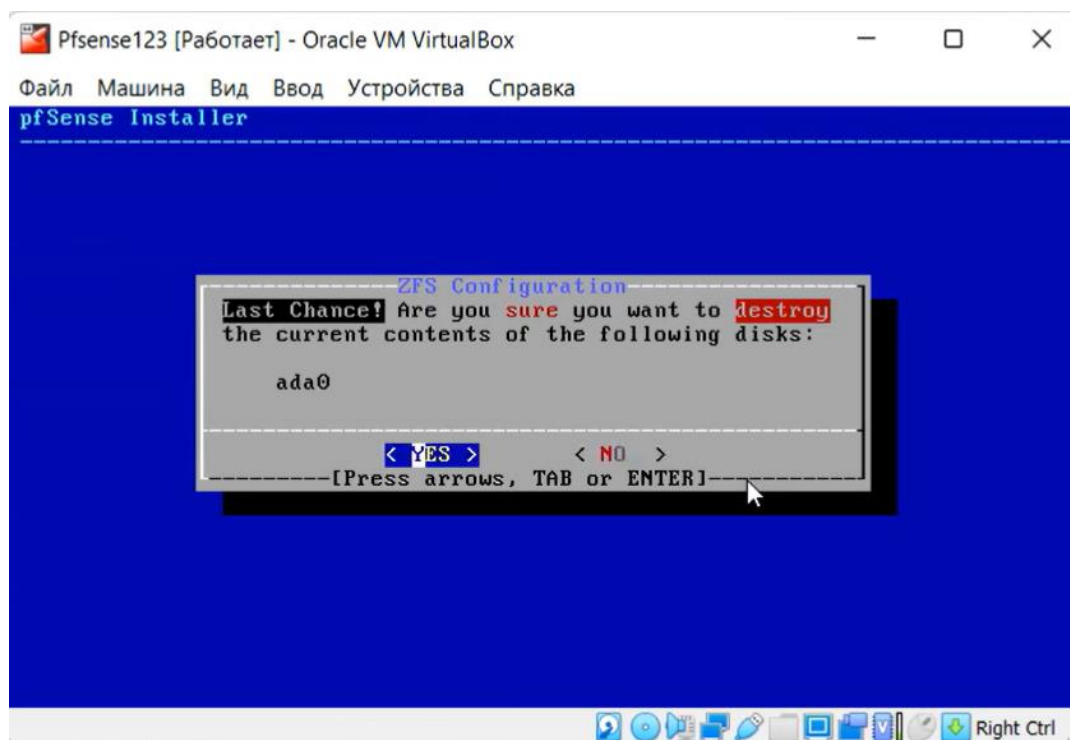


Рисунок 5 – Предупреждение системы pfSense

Процесс установки системы pfSense представлен на рисунке 6.

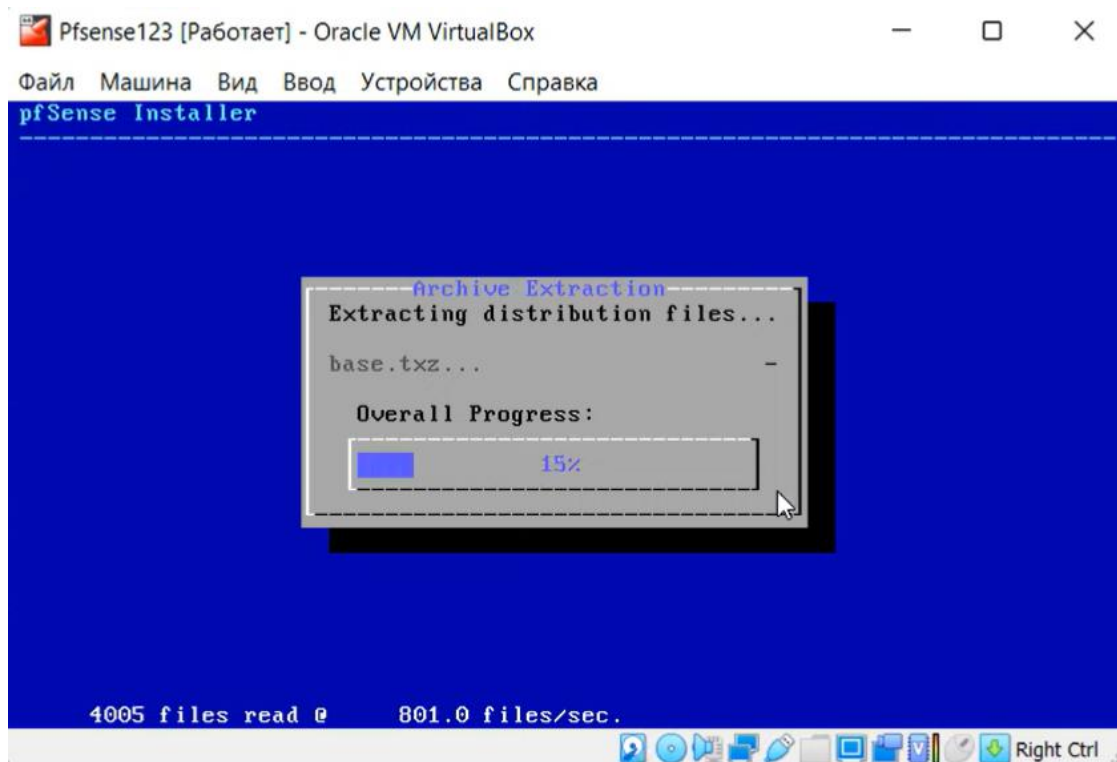


Рисунок 6 – Процесс установки системы pfSense

Для завершения установки системы pfSense требуется перезагрузка. Сообщение о перезагрузке системы представлено на рисунке 7.

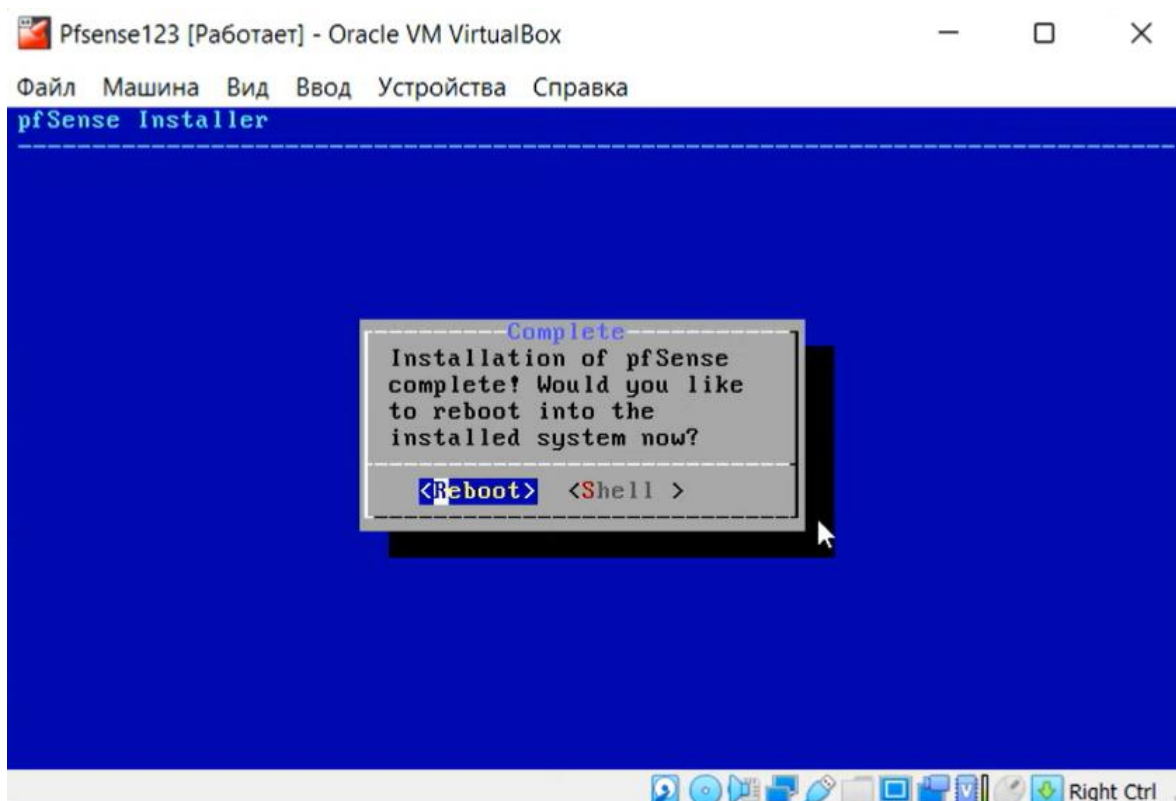


Рисунок 7 – Сообщение о перезагрузке системы

Интерфейс системы pfSense представлен на рисунке 8.

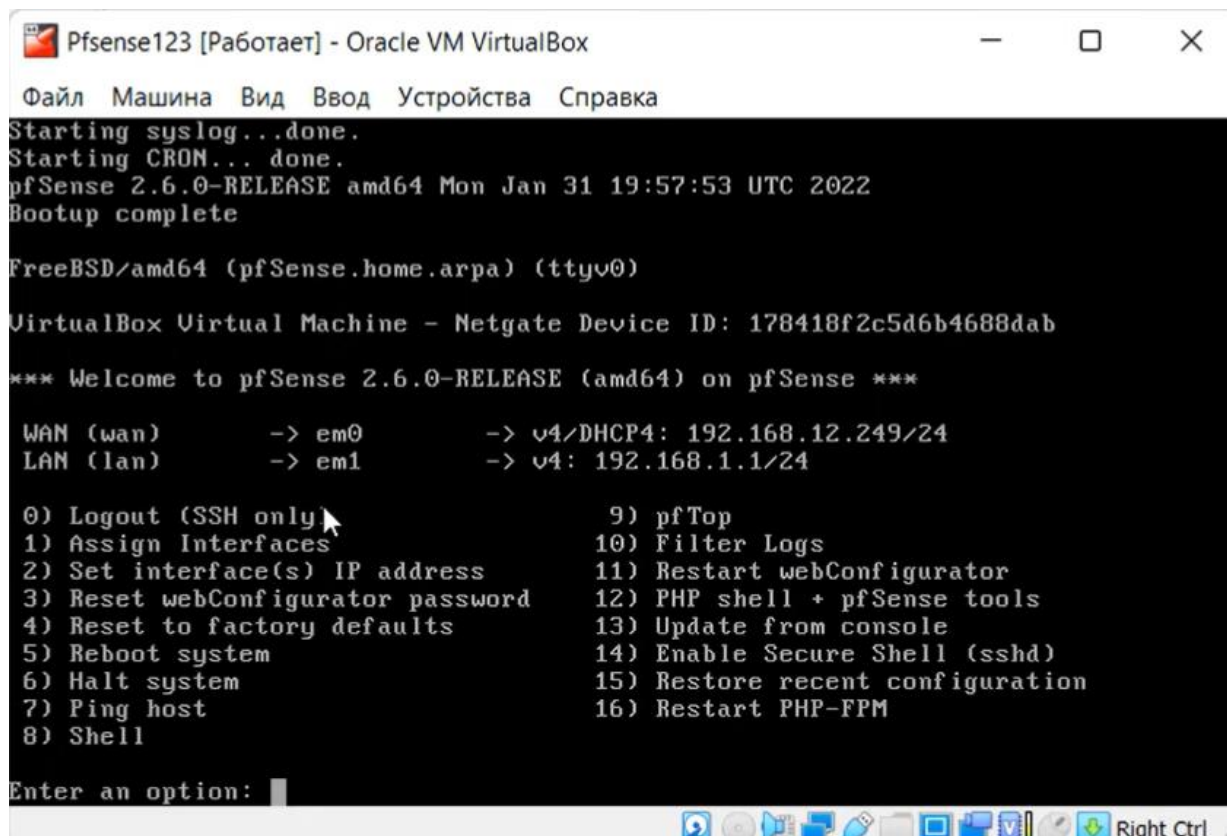


Рисунок 8 – Интерфейс системы pfSense

Настройка системы pfSense производится с операционной системы (далее – ОС) Windows 10. Меню настройки системы pfSense в браузере представлено на рисунке 9. Логин: admin. Пароль: pfSense.

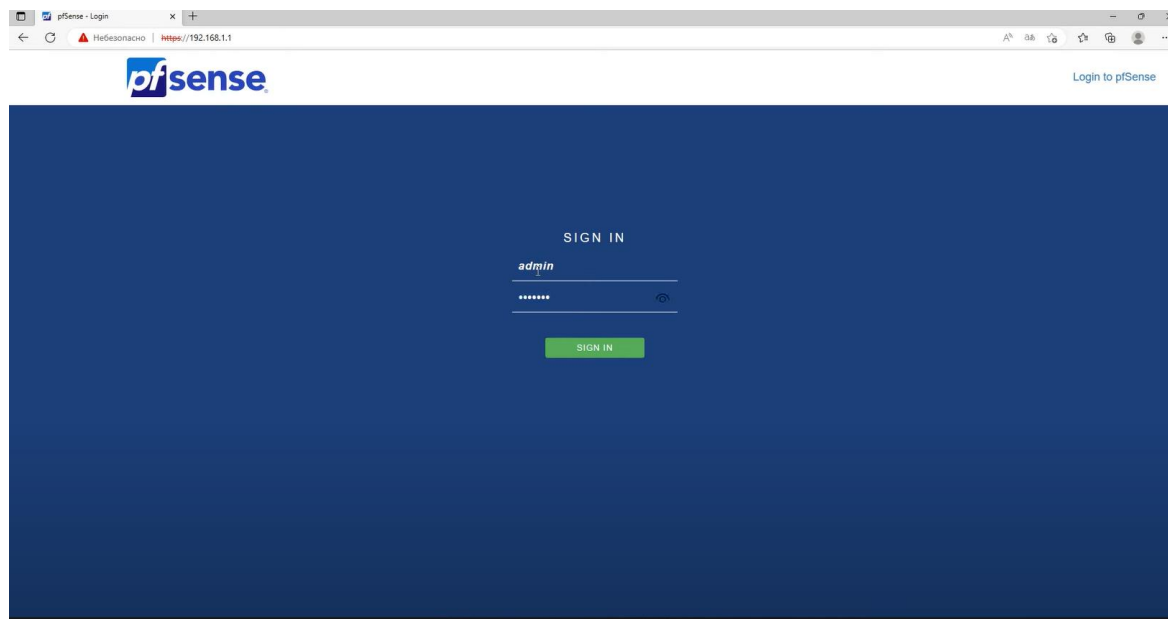


Рисунок 9 – Меню настройки системы pfSense в браузере

После ввода логина и пароля появляется окно приветствия. Окно приветствия представлено на рисунке 10.

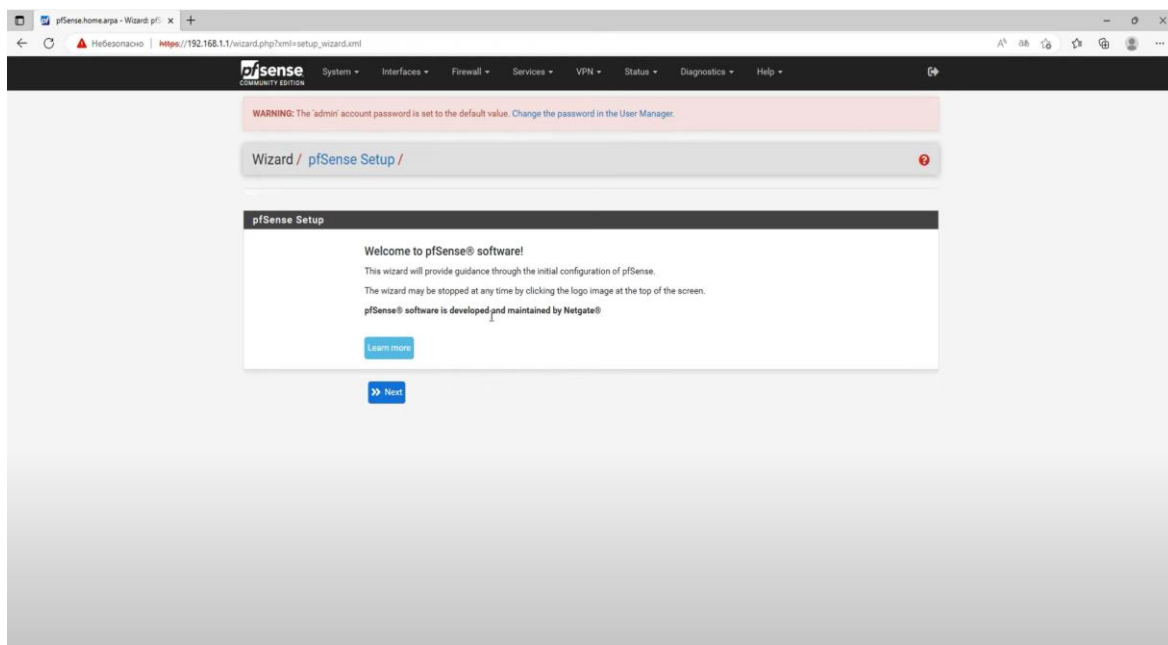


Рисунок 10 – Окно приветствия

Следующим шагом происходит настройка имени сервера – pfSense (Hostname), также домена сервера – home.arpa (Domain) и протокола DNS. Настройка Hostname, Domain и протокола DNS представлена на рисунке 11.

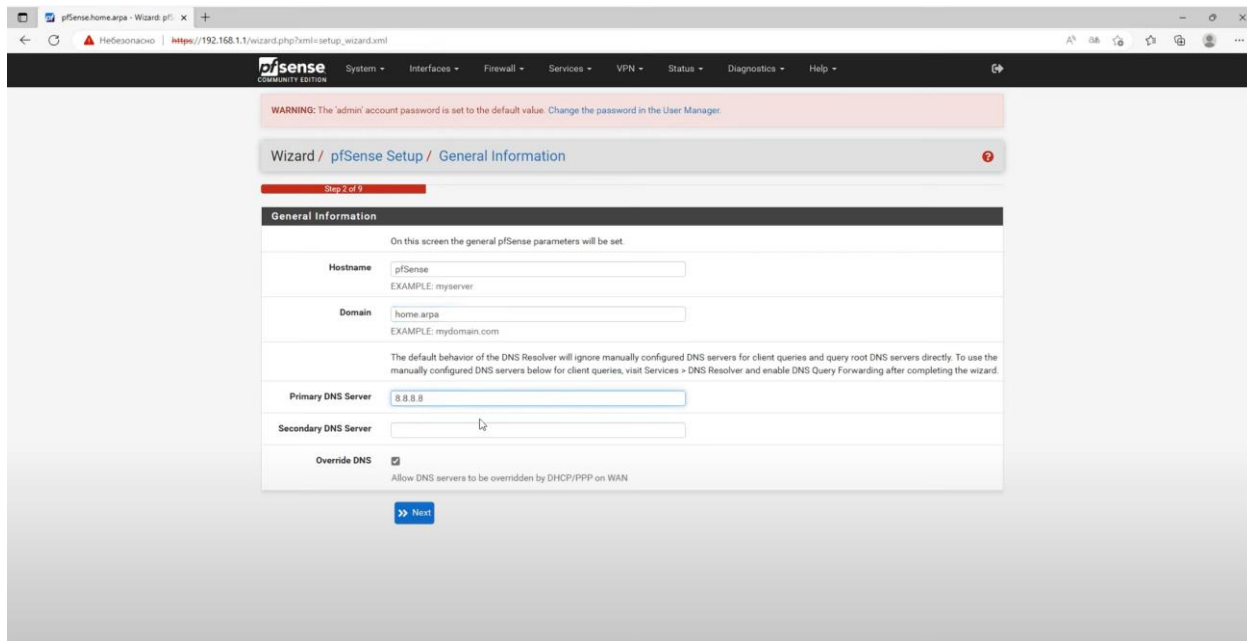


Рисунок 11 – Настройка Hostname, Domain и протокола DNS

Осуществляется настройка протокола NTP. В настройке прописывается город – Новокузнецк. Настройка протокола NTP представлена на рисунке 12.

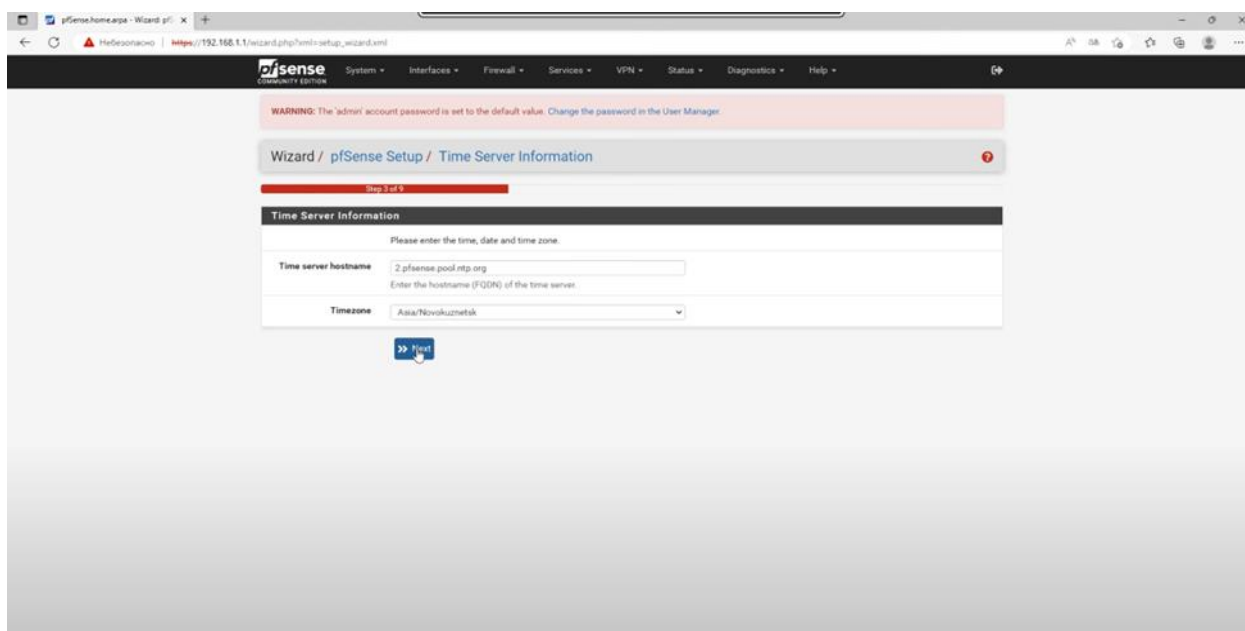


Рисунок 12 – Настройка протокола NTP

Далее происходит настройка WAN интерфейса. На данном этапе настройки каждый параметр зависит от провайдера. Выбран способ – настройка с помощью протокола DHCP. Настройка WAN интерфейса представлена на рисунке 13.

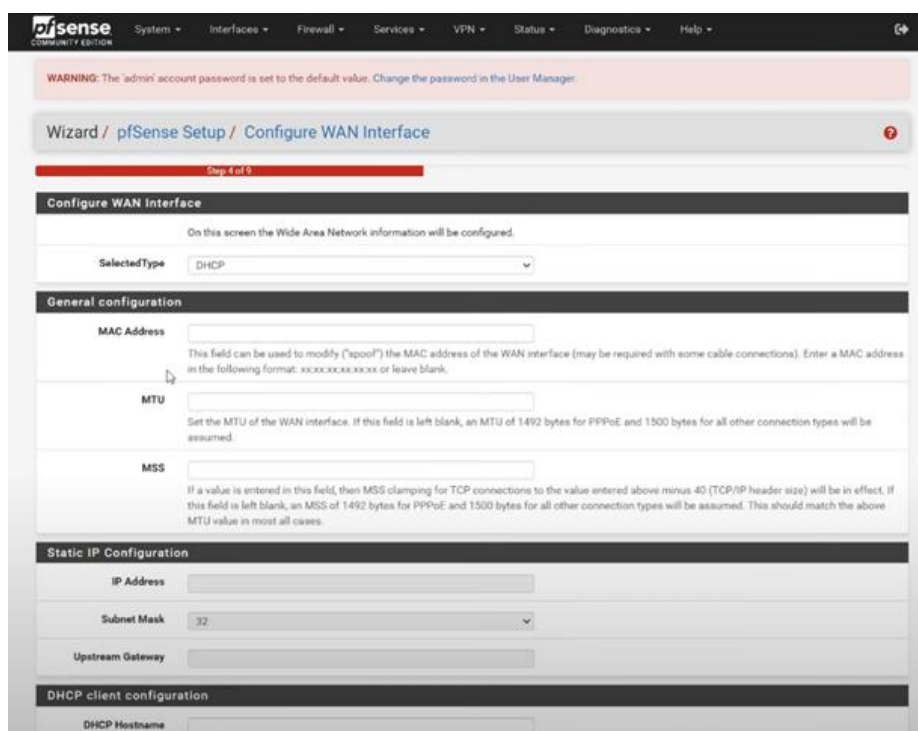


Рисунок 13 – Настройка WAN интерфейса

Следующим шагом происходит настройка LAN интерфейса. Подсеть: 49. Маска: 32. Настройка LAN интерфейса представлена на рисунке 14.

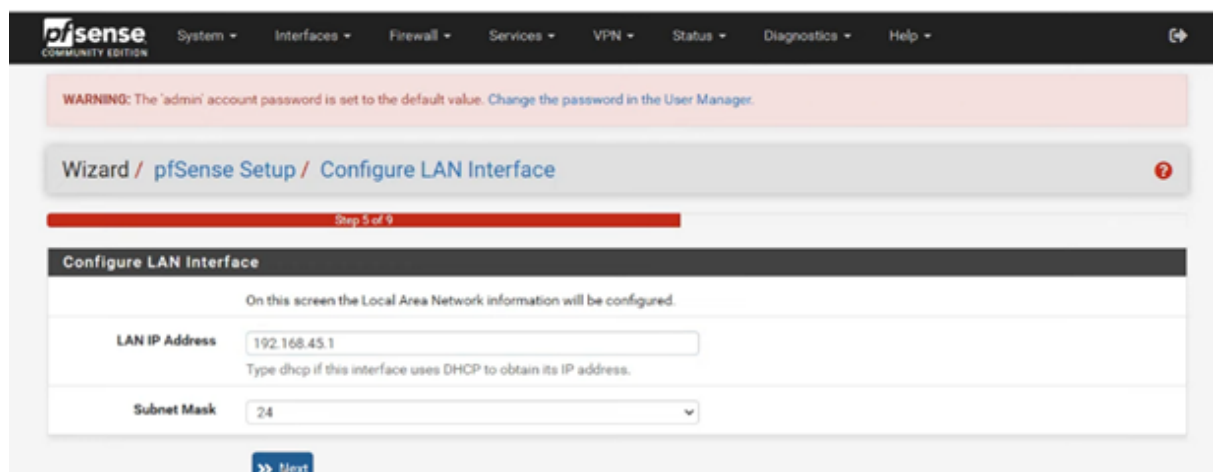


Рисунок 14 – Настройка LAN интерфейса

Одним из немаловажных шагов является смена пароля. Новый пароль – Pfsense1. Смена пароля представлена на рисунке 15.

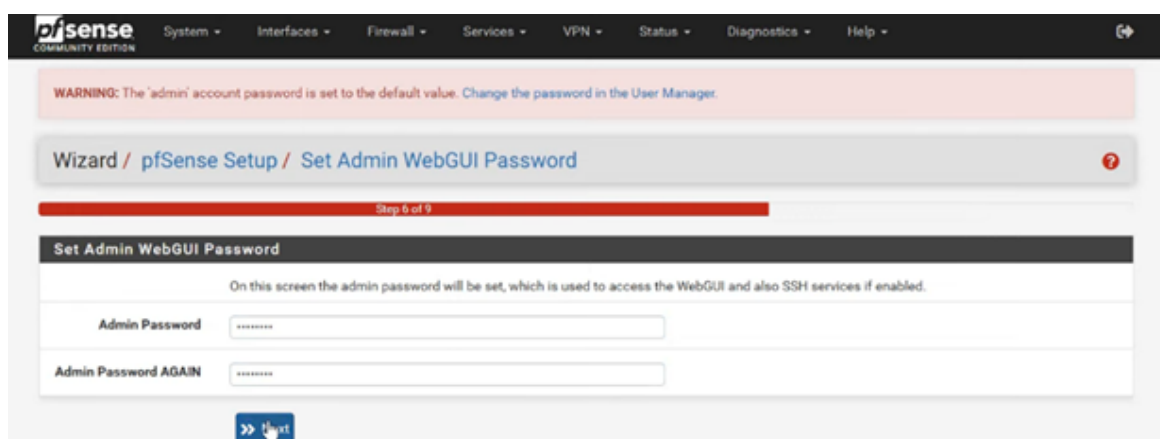


Рисунок 15 – Смена пароля

Система просит перезагрузить страницу, чтобы все шаги вступили в силу. Окно перезагрузки представлено на рисунке 16.

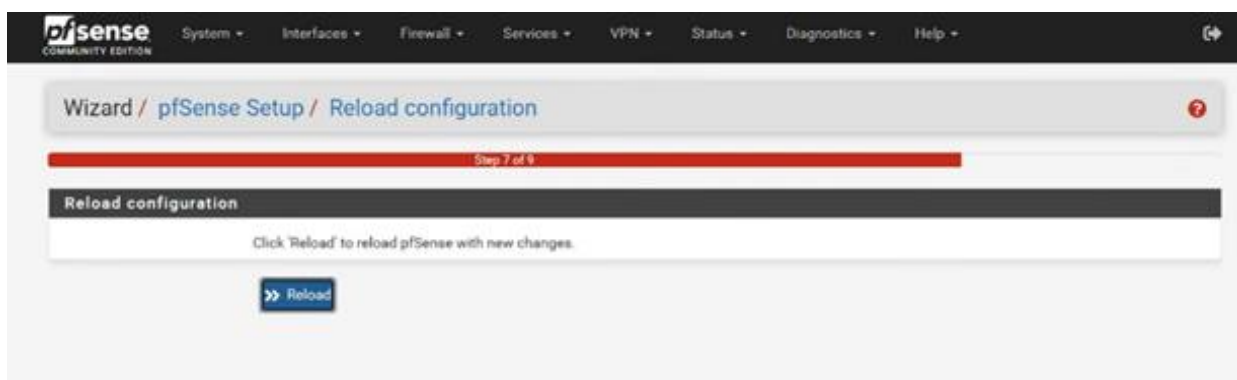


Рисунок 16 – Окно перезагрузки

После проделанных настроек происходит переход на основной интерфейс pfSense. Основной интерфейс pfSense представлен на рисунке 17.

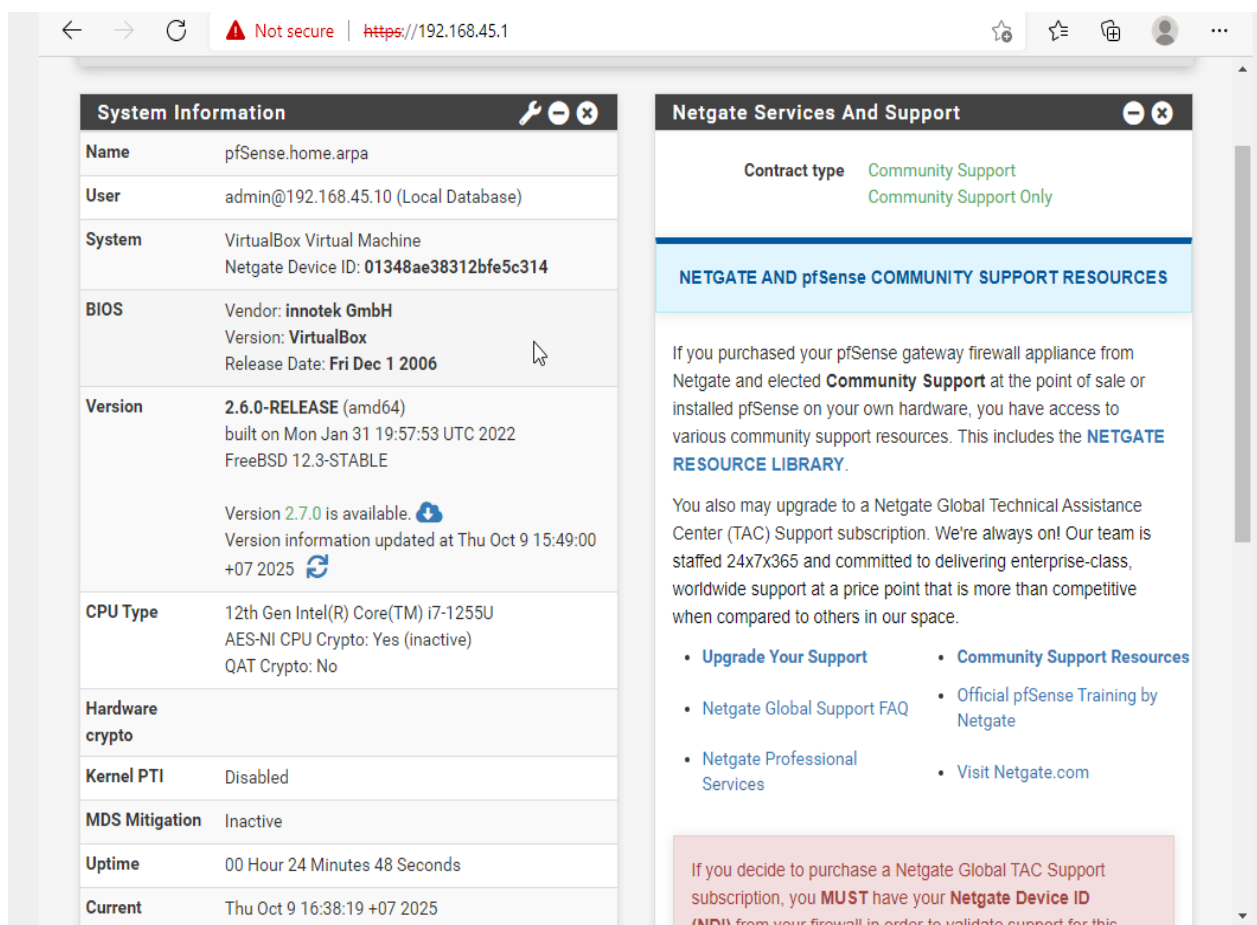


Рисунок 17 – Основной интерфейс pfSense

В левой части расположено меню с разделами (System, Interfaces, Firewall, Services). В центральной области – страницы с настройками и статусом системы [23].

3.3 Реализация политики фильтрации трафика и устранение выявленных уязвимостей

В исходной архитектуре корпоративной сети ООО «Авангард Бюро» рабочие станции сотрудников и тестовые узлы находились в одном сетевом сегменте. Это позволяло любому устройству внутри сети напрямую обращаться к другим хостам, что создавало угрозу горизонтального перемещения злоумышленника и отсутствия контроля межсетевого взаимодействия.

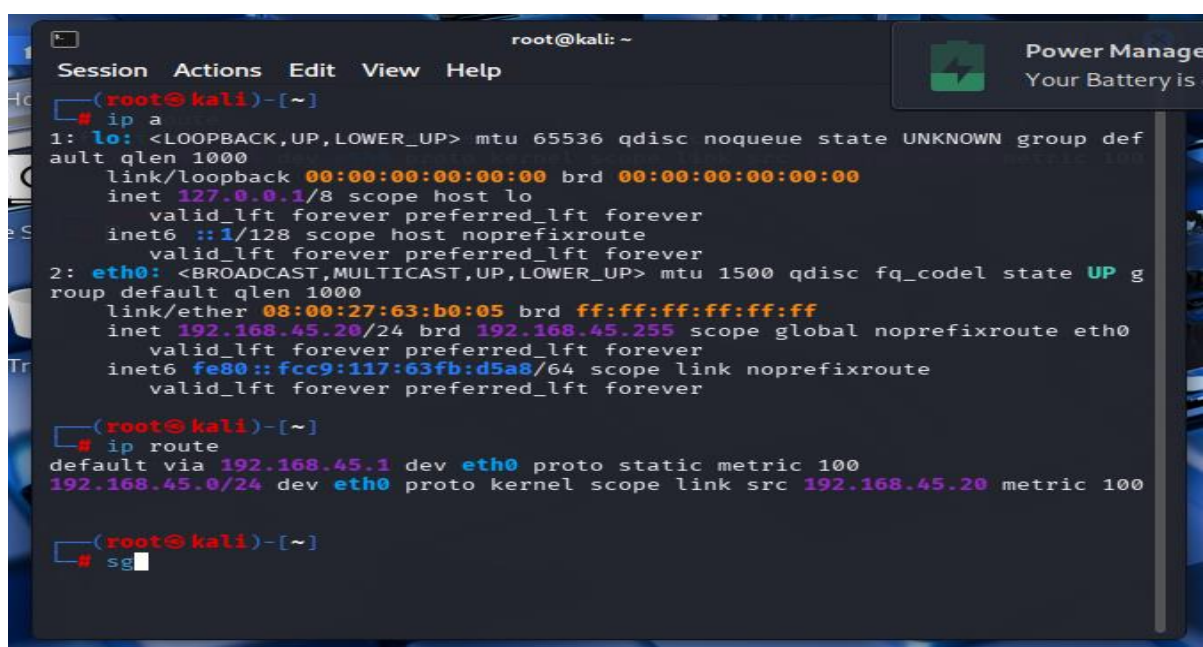
На рисунке 18 представлена сетевая конфигурация рабочей станции сотрудника под управлением Windows.

```
Connection-specific DNS Suffix . : home.arpa
Link-local IPv6 Address . . . . . : fe80::3d9a:6943:4ac9:f3d4%3
IPv4 Address. . . . . : 192.168.45.10
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : fe80::a00:27ff:fe1b:18ea%3
                            192.168.45.1
```

Рисунок 18 – Сетевая конфигурация рабочей станции

Рабочая станция сотрудника под управлением Windows имеет адрес из подсети 192.168.45.0 и использует шлюз 192.168.45.1.

На рисунке 19 представлена сетевая конфигурация тестового узла под управлением Kali Linux.



```
root@kali: ~
Session Actions Edit View Help
(root@kali)-[~]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.45.20/24 brd 192.168.45.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::fcc9:117:63fb:d5a8/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(root@kali)-[~]
# ip route
default via 192.168.45.1 dev eth0 proto static metric 100
192.168.45.0/24 dev eth0 proto kernel scope link src 192.168.45.20 metric 100

(root@kali)-[~]
# sg
```

Рисунок 19 – Сетевая конфигурация тестового узла

Тестовый узел под управлением Kali Linux также имеет адрес из подсети 192.168.45.0 и также использует шлюз 192.168.45.1.

Отсутствие сегментации подтверждается успешным выполнением команды «ping» с рабочей станции на тестовый узел, что демонстрирует рисунок 20.

```
C:\Users\admin>ping 192.168.45.20

Pinging 192.168.45.20 with 32 bytes of data:
Reply from 192.168.45.20: bytes=32 time=3ms TTL=64
Reply from 192.168.45.20: bytes=32 time=1ms TTL=64
Reply from 192.168.45.20: bytes=32 time=1ms TTL=64
Reply from 192.168.45.20: bytes=32 time=1ms TTL=64

Ping statistics for 192.168.45.20:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 1ms, Maximum = 3ms, Average = 1ms
```

Рисунок 20 – Успешное выполнение команды «ping»

Трассировка маршрута с помощью команды «tracert» показывает прямое соединение без участия МЭ, показана на рисунке 21.

```
C:\Users\admin>tracert 192.168.45.20

Tracing route to 192.168.45.20 over a maximum of 30 hops

  1    2 ms    2 ms    3 ms  192.168.45.20

Trace complete.

C:\Users\admin>
```

Рисунок 21 – Трассировка маршрута без участия МЭ

Трафик между устройствами проходил напрямую, минуя pfSense, что подтверждается отсутствием записей в журнале МЭ. Отсутствие записей показано на рисунке 22.

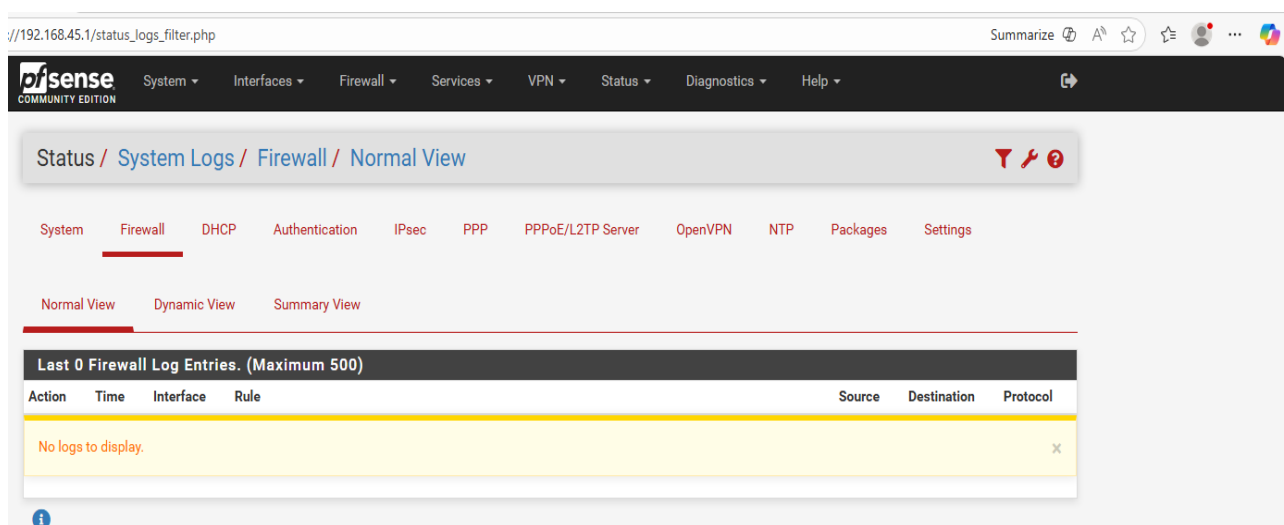


Рисунок 22 – Отсутствие записей

Для устранения уязвимости была выполнена сегментация сети:

- сегмент LAN (192.168.45.0/24) – рабочие станции сотрудников;
- сегмент Optional Interface 1 (далее – OPT1) (192.168.50.0/24) – тестовые и потенциально опасные узлы.

На межсетевом экране pfSense был создан интерфейс OPT1. Интерфейс OPT1 показан на рисунке 23.

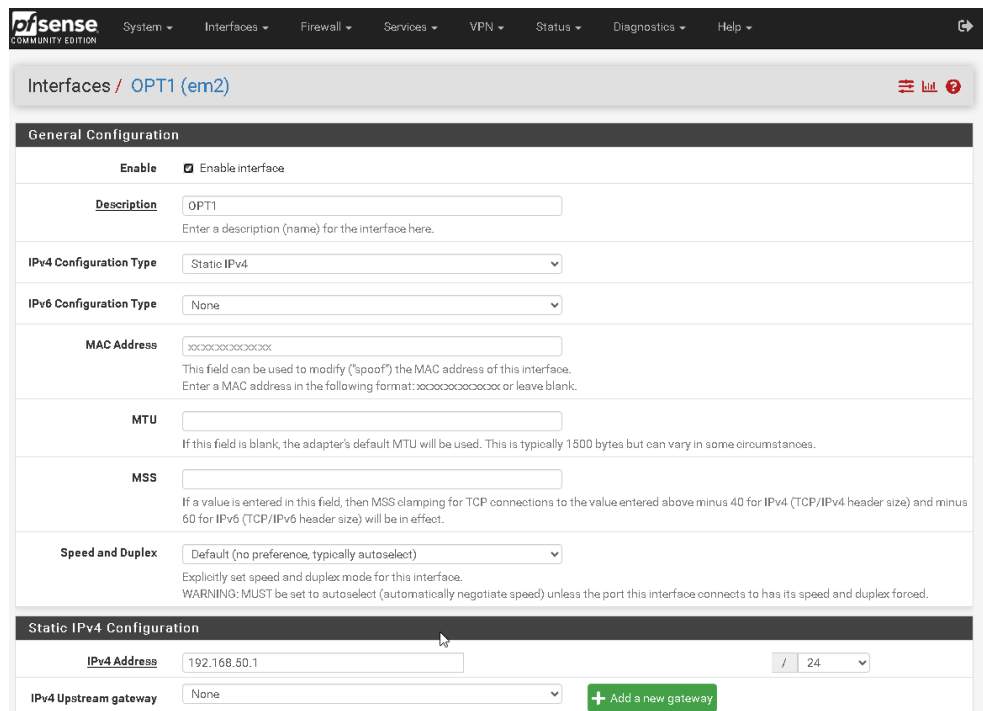


Рисунок 23 – Интерфейс OPT1

Тестовый узел под управлением Kali Linux был переведён в новую подсеть. Перевод тестового узла в новую подсеть показан на рисунке 24.

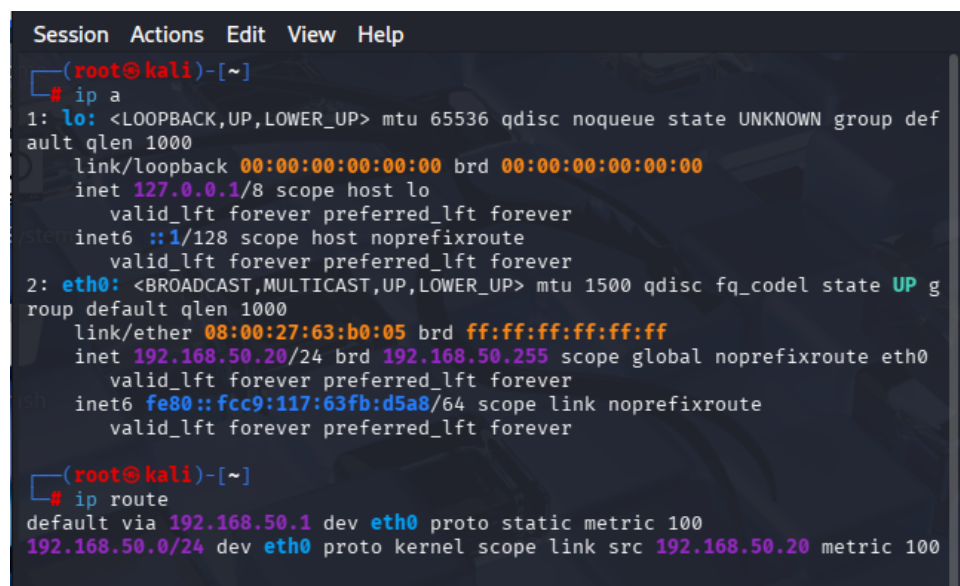


Рисунок 24 – Перевод тестового узла

Тестовой узел получил адрес 192.168.50.20 из новой подсети и отображает шлюз 192.168.50.1.

После разделения сети трафик между сегментами стал проходить через pfSense, что подтверждается результатами трассировки маршрута. Трассировка маршрута показана на рисунке 25.

```
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\admin>tracert 192.168.50.20

Tracing route to 192.168.50.20 over a maximum of 30 hops

  1    7 ms    1 ms    5 ms  pfSense.home.arpa [192.168.45.1]
  2   15 ms    6 ms    5 ms  192.168.50.20

Trace complete.
```

Рисунок 25 – Трассировка маршрута

Теперь первый хоп – это интерфейс LAN межсетевого экрана, а второй – адрес узла в сегменте OPT1.

Для демонстрации работы pfSense были созданы два правила на интерфейсе LAN, так как pfSense фильтрует трафик на входе в интерфейс:

1. Правило «Allow LAN to OPT1». Это правило позволяет рабочим станциям обращаться к тестовому сегменту. Правило показано на рисунке 26.

The screenshot shows the 'Edit Firewall Rule' configuration page in pfSense. The rule is named 'Allow LAN to OPT1'. The 'Action' is set to 'Pass'. The 'Interface' is 'LAN'. The 'Address Family' is 'IPv4'. The 'Protocol' is 'Any'. The 'Source' is 'LAN net' and the 'Destination' is 'OPT1 net'. The 'Log' checkbox is unchecked. The 'Description' is 'Allow LAN to OPT1'. The 'Advanced Options' section is expanded, showing a 'Display Advanced' button.

Edit Firewall Rule	
Action	Pass
Disabled	☐ Disable this rule
Interface	LAN
Address Family	IPv4
Protocol	Any
Source	
Source	☐ Invert match LAN net
Destination	
Destination	☐ Invert match OPT1 net
Extra Options	
Log	☐ Log packets that are handled by this rule
Description	Allow LAN to OPT1
Advanced Options	☒ Display Advanced

Рисунок 26 – Правило «Allow LAN to OPT1»

После применения разрешающего правила рабочая станция получила возможность обращаться к тестовому узлу, расположенному в сегменте OPT1. Обращение показано на рисунке 27.

```
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\admin>ping 192.168.50.20

Pinging 192.168.50.20 with 32 bytes of data:
Reply from 192.168.50.20: bytes=32 time=26ms TTL=63
Reply from 192.168.50.20: bytes=32 time=13ms TTL=63
Reply from 192.168.50.20: bytes=32 time=12ms TTL=63
Reply from 192.168.50.20: bytes=32 time=3ms TTL=63

Ping statistics for 192.168.50.20:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 3ms, Maximum = 26ms, Average = 13ms

C:\Users\admin>
```

Рисунок 27 – Обращение к тестовому узлу после применения правила 1

2. Правило «Block LAN to OPT1». Это правило запрещает доступ из сегмента LAN в сегмент OPT1. Правило показано на рисунке 28.

The screenshot shows the 'Edit Firewall Rule' window in Windows Firewall. The rule is named 'Block LAN to OPT1'. The 'Action' is set to 'Block'. The 'Interface' is 'LAN'. The 'Address Family' is 'IPv4'. The 'Protocol' is 'Any'. The 'Source' is 'LAN net' and the 'Destination' is 'OPT1 net'. The 'Log' checkbox is checked. The 'Description' is 'Block LAN to OPT1'. The 'Advanced Options' section is expanded, showing a 'Display Advanced' button.

Рисунок 28 – Правило «Block LAN to OPT1»

После включения правила рабочая станция не может обратиться к тестовому узлу. Обращение показано на рисунке 29.

```
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\admin>ping 192.168.50.20

Pinging 192.168.50.20 with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 192.168.50.20:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\Users\admin>
```

Рисунок 29 – Обращение рабочей станции к тестовому узлу после включения правила

После включения блокирующего правила межсетевой экран pfSense фиксирует попытки обращения рабочей станции к тестовому узлу и блокирует их. На рисунке 30 показана запись в журнале межсетевого экрана, подтверждающая срабатывание правила «Block LAN to OPT1».

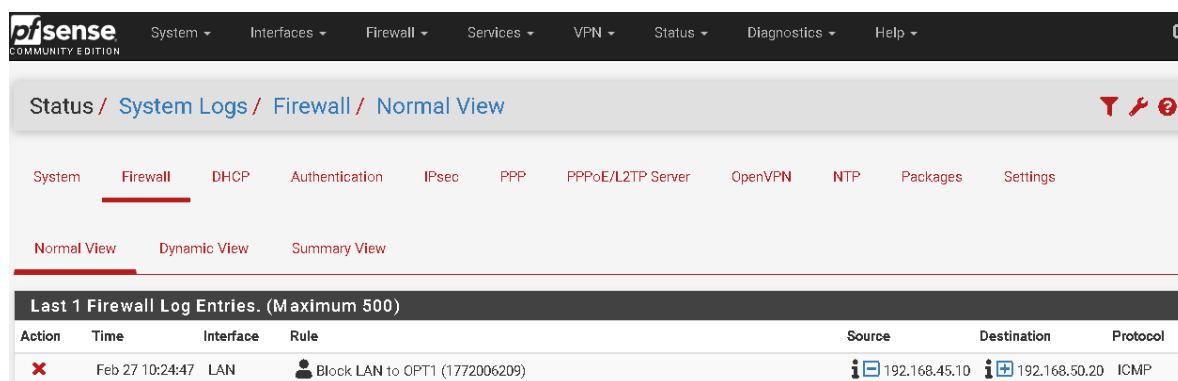


Рисунок 30 – Запись в журнале

Отсутствие сегментации между LAN и OPT1 позволяло рабочей станции свободно обращаться к тестовому узлу, что создавало риск несанкционированного доступа. После применения блокирующего правила на интерфейсе LAN доступ был успешно ограничен, что подтверждается как результатами проверки, так и записями в журнале pfSense. Уязвимость устранена.

После устранения проблемы, связанной с отсутствием сегментации внутренних сетей, осуществляется переход ко второй уязвимости, связанной

с доступностью внутренних сервисов из внешней сети.

Для моделирования инфраструктуры разворачивался стенд из трёх узлов. Стенд продемонстрирован в таблице 4.

Таблица 4 – Стенд

Узел	Назначение	Сеть
MikroTik	Эмуляция провайдера	192.168.100.0/24
PfSense	Межсетевой экран	WAN:192.168.100.50 LAN:192.168.45.1
Windows	Клиентская машина	192.168.45.0/24

MikroTik выполняет роль «провайдера» и выдаёт pfSense WAN-адрес через DHCP. PfSense раздаёт LAN-адреса клиентским ПК под управлением Windows.

Чтобы pfSense получил WAN-адрес и стал доступен извне, на MikroTik были написаны команды. Переименование интерфейса ether1 показано на рисунке 31.

```
Flags: R - RUNNING
Columns: NAME, TYPE, ACTUAL-MTU, MAC-ADDRESS
# NAME TYPE ACTUAL-MTU MAC-ADDRESS
0 R internet ether 1500 08:00:27:D4:9F:88
1 R provider ether 1500 08:00:27:CC:7F:3E
2 R lo loopback 65536 00:00:00:00:00:00
[admin@MikroTik] > /interface set ether1 name=internet
```

Рисунок 31 – Переименование интерфейса ether1

Переименование интерфейса ether2 показано на рисунке 32.

```
[admin@MikroTik] > /interface print
Flags: R - RUNNING
Columns: NAME, TYPE, ACTUAL-MTU, MAC-ADDRESS
# NAME TYPE ACTUAL-MTU MAC-ADDRESS
0 R internet ether 1500 08:00:27:D4:9F:88
1 R provider ether 1500 08:00:27:CC:7F:3E
2 R lo loopback 65536 00:00:00:00:00:00
[admin@MikroTik] > /interface set ether2 name=provider_
```

Рисунок 32 – Переименование интерфейса ether2

Далее производится назначение IP-адреса на интерфейс provider (рисунок 33).


```
[admin@MikroTik] > /interface print
Flags: R - RUNNING
Columns: NAME, TYPE, ACTUAL-MTU, MAC-ADDRESS
#  NAME      TYPE      ACTUAL-MTU  MAC-ADDRESS
0  R internet  ether      1500        08:00:27:D4:9F:88
1  R provider  ether      1500        08:00:27:CC:7F:3E
2  R lo        loopback   65536       00:00:00:00:00:00
[admin@MikroTik] > /ip address add address=192.168.100.1/24 interface=provider
```

Рисунок 33 – Назначение IP-адреса на интерфейс provider

Производится настройка DHCP-сервера в сети 192.168.100.0/24, к которой подключён WAN-интерфейс pfSense. Настройка DHCP-сервера показана на рисунке 34.

```
[admin@MikroTik] > /interface print
Flags: R - RUNNING
Columns: NAME, TYPE, ACTUAL-MTU, MAC-ADDRESS
#  NAME      TYPE      ACTUAL-MTU  MAC-ADDRESS
0  R internet  ether      1500        08:00:27:D4:9F:88
1  R provider  ether      1500        08:00:27:CC:7F:3E
2  R lo        loopback   65536       00:00:00:00:00:00
[admin@MikroTik] > /ip pool add name=wanpool ranges=192.168.100.10-192.168.100.50
[admin@MikroTik] > /ip dhcp-server add name=dhcp-wan interface=provider address-pool=wanpool disabled=no
[admin@MikroTik] > /ip dhcp-server network add address=192.168.100.0/24 gateway=192.168.100.1
```

Рисунок 34 – Настройка DHCP-сервера

Для завершения работы провайдера на маршрутизаторе MikroTik был настроен NAT. Настройка NAT показана на рисунке 35.

```
[admin@MikroTik] > /interface print
Flags: R - RUNNING
Columns: NAME, TYPE, ACTUAL-MTU, MAC-ADDRESS
#  NAME      TYPE      ACTUAL-MTU  MAC-ADDRESS
0  R internet  ether      1500        08:00:27:D4:9F:88
1  R provider  ether      1500        08:00:27:CC:7F:3E
2  R lo        loopback   65536       00:00:00:00:00:00
[admin@MikroTik] > /ip firewall nat add chain=srcnat out-interface=internet action=masquerade
```

Рисунок 35 – Настройка NAT

После настройки MikroTik pfSense получил WAN-адрес из сети 192.168.100.0/24. Интерфейсы pfSense после настройки MikroTik показаны на рисунке 36.

```
*** Welcome to pfSense 2.6.0-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.100.50/24
LAN (lan)      -> em1      -> v4: 192.168.45.1/24
OPT1 (opt1)    -> em2      -> v4: 192.168.50.1/24
```

Рисунок 36 – Интерфейсы pfSense после настройки MikroTik

Для демонстрации уязвимости на pfSense были созданы разрешающие правило на WAN-интерфейсе, разрешающее доступ извне: разрешение TCP-трафика (рисунок 37).

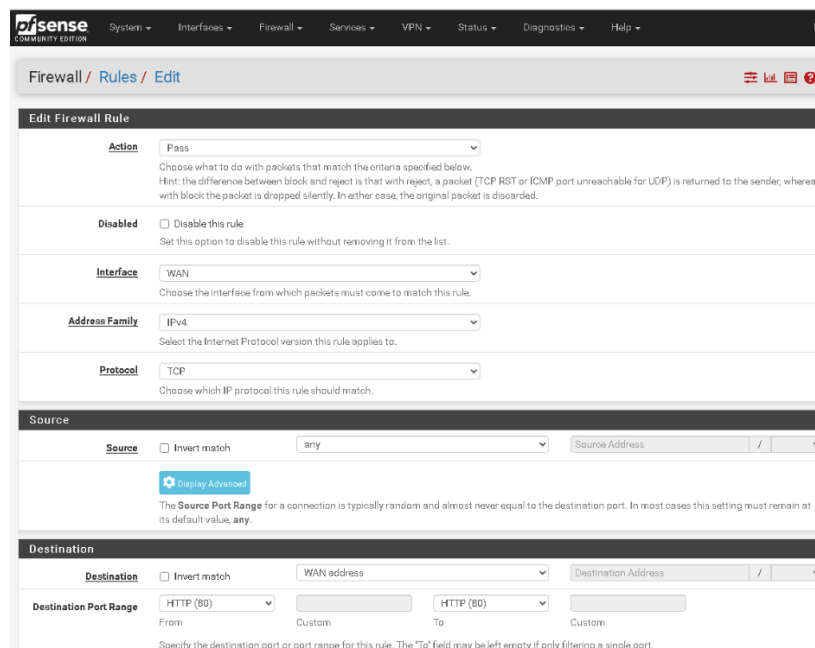


Рисунок 37 – Разрешение TCP-трафика

Оба правила демонстрируют неправильную конфигурацию МЭ, при которой административная панель pfSense становится доступной из внешней сети. Доступность графического интерфейса pfSense с машины Windows показана на рисунке 38.

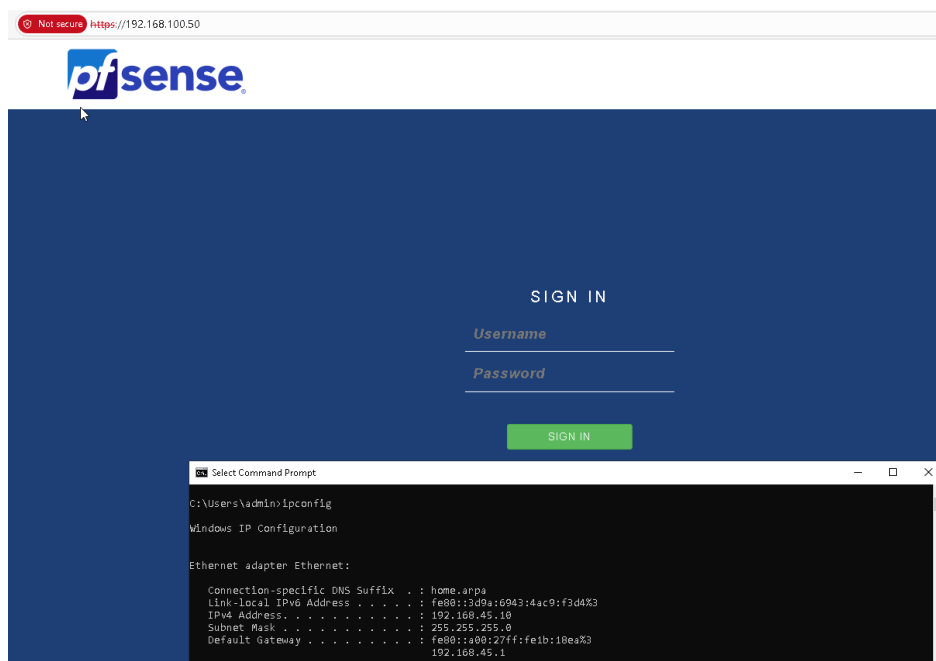


Рисунок 38 – Доступность графического интерфейса

После демонстрации уязвимости проведено её устранение. Для этого было осуществлено удаление разрешающего TCP-трафик правила. Процесс удаления правила показан на рисунке 39.

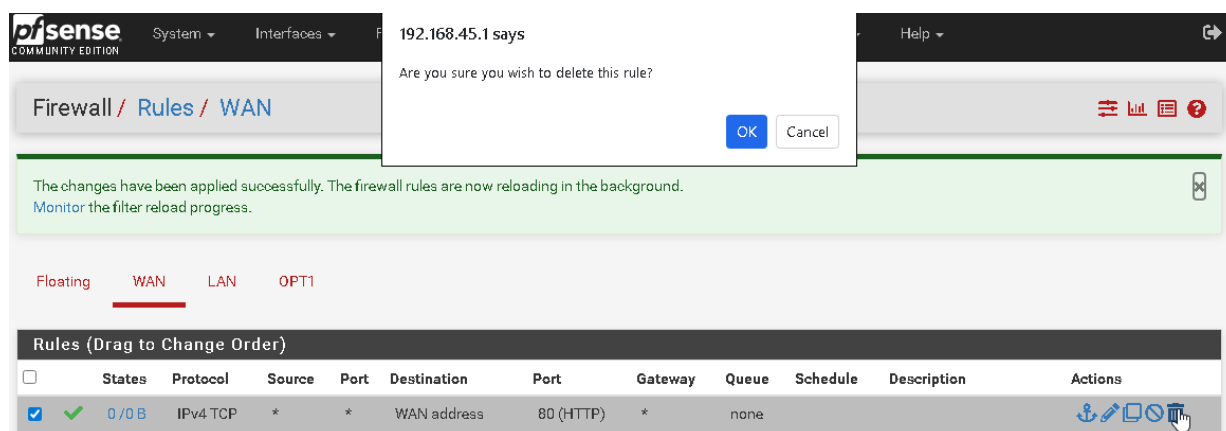


Рисунок 39 – Процесс удаления правила

Также на WAN-интерфейсе была включена опция «Block private networks» (рисунок 40).

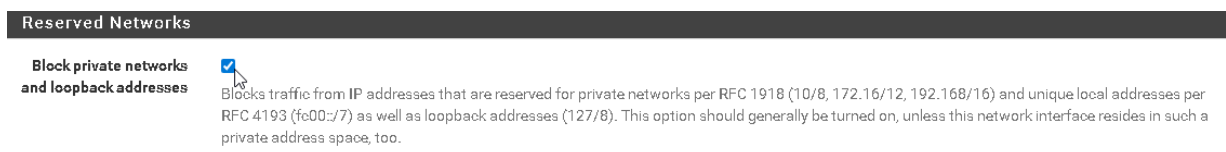


Рисунок 40 – Включение опции «Block private networks»

После выполненных настроек доступ с машины Windows к графическому интерфейсу pfSense по WAN-адресу прекратился (рисунок 41).

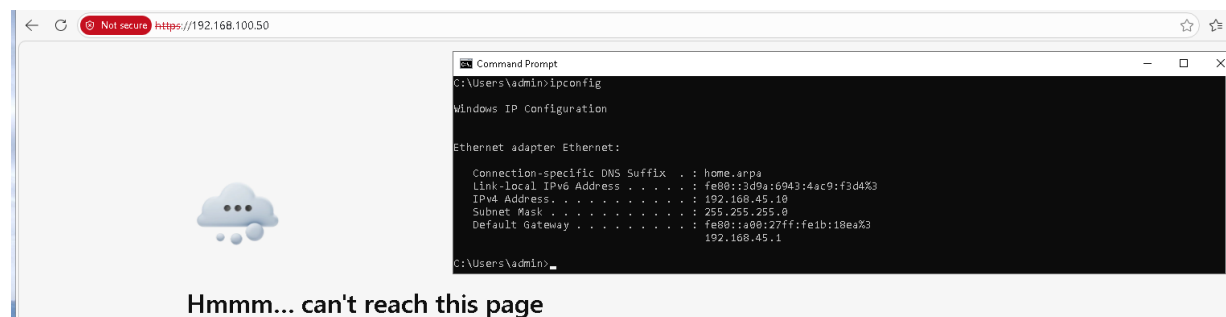


Рисунок 41 – Доступ к графическому интерфейсу после выполненных настроек

Уязвимость успешно устранена.

После устранения проблемы, связанной с получением доступа из внешней сети, осуществляется переход к третьей уязвимости, связанной с

отсутствием корректной фильтрации пользовательского ввода во внутреннем веб-приложении.

Для демонстрации уязвимости была создана простая веб-страница на тестовый узел, доступная по HTTP. Страница представляет собой форму создания служебной записки:

- поле «Тема»;
- поле «Текст служебной записки»;
- кнопка «Сохранить».

Форма создания служебной записки показана на рисунке 42.

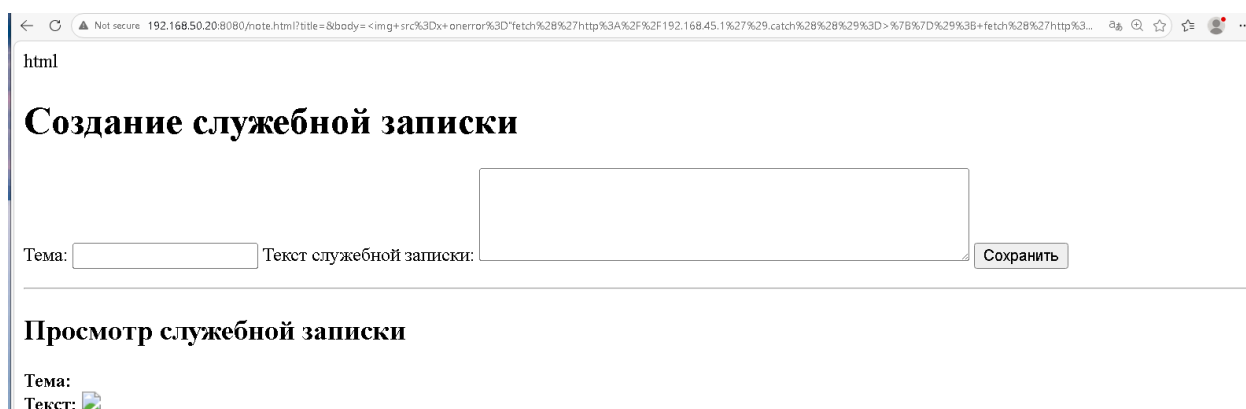


Рисунок 42 – Форма создания служебной записки

Для проверки уязвимости в поле «Текст служебной записки» был введён фрагмент: «».

После отправки формы браузер выполнил JavaScript-код, что привело к появлению всплывающего окна с сообщением «XSS» (рисунок 43).

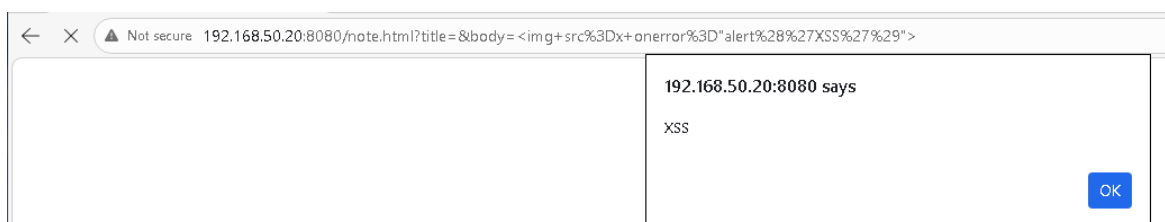


Рисунок 43 – Сообщение «XSS»

Следующим этапом было продемонстрировано, что XSS позволяет выполнять сетевые запросы от имени пользователя. В поле был введён код: «».

После отправки формы во вкладке «Network» инструментов

разработчиков браузера появилась попытка обращения к внешнему серверу (рисунок 44).

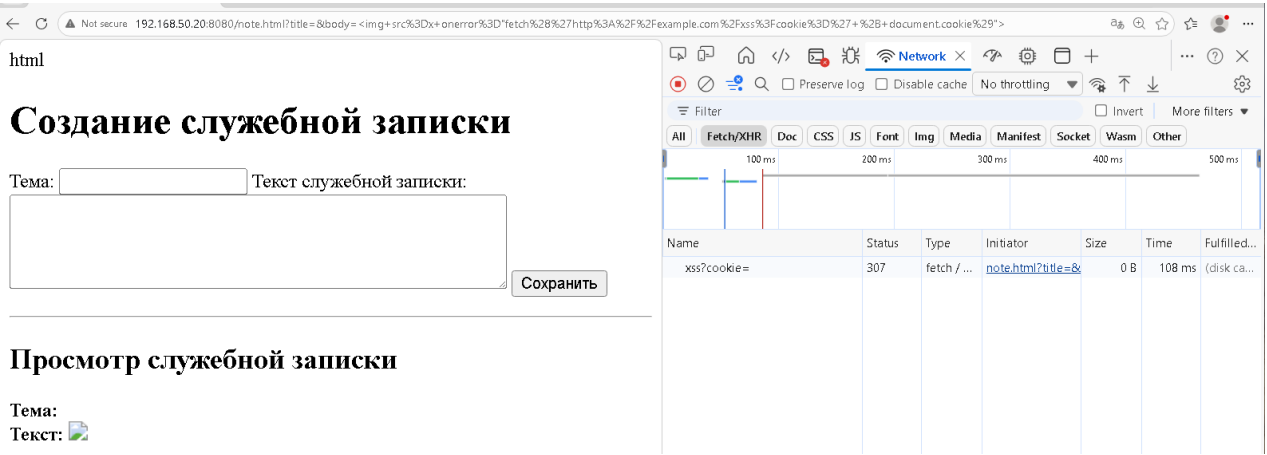


Рисунок 44 – Попытка обращения к внешнему серверу

Для демонстрации внутренней угрозы был выполнен следующий код:

```
«<img                                src=x                                onerror="
fetch('http://192.168.45.1').catch(()=>{});
fetch('http://192.168.100.50').catch(()=>{});
">».
```

Браузер попытался обратиться к внутренним IP-адресам, что подтверждает возможность использовать XSS для сканирования сети. Обращение к внутренним IP-адресам показано на рисунке 45.

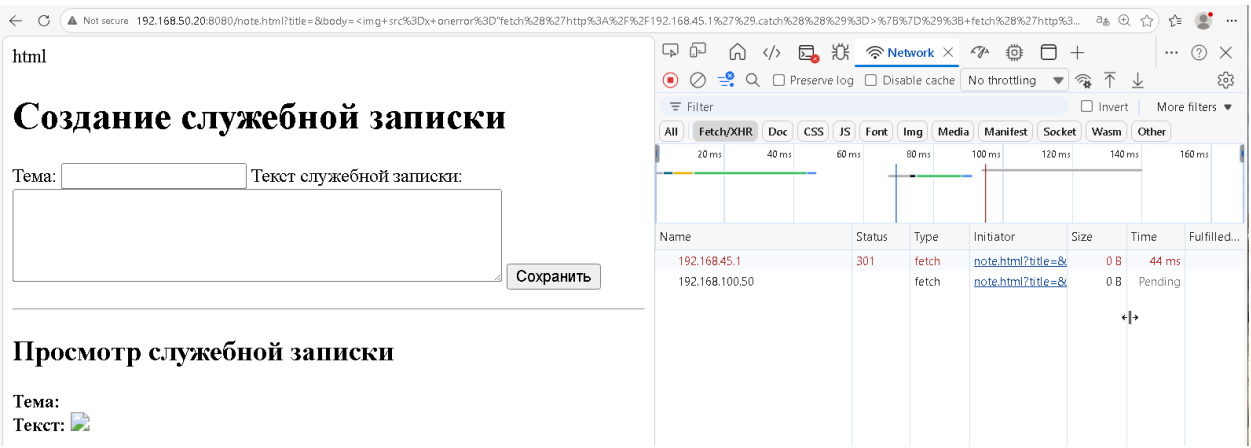


Рисунок 45 – Обращение к внутренним IP-адресам

Для минимизации последствий XSS была выполнена настройка МЭ. Цель: не устранить уязвимость на странице, а ограничить вред, который может нанести вредоносный JavaScript.

Правило «Блокировка исходящих HTTP-запросов» продемонстрировано на рисунке 46.

The screenshot shows the 'Edit Firewall Rule' configuration window. The 'Action' is set to 'Block'. The 'Interface' is 'LAN'. The 'Address Family' is 'IPv4'. The 'Protocol' is 'TCP/UDP'. The 'Source' is 'LAN net'. The 'Destination' is 'any'. The 'Destination Port Range' is set to 'HTTP (80)'. The 'Log' checkbox is checked. The 'Description' is 'Block outbound HTTP (XSS protection)'.

Edit Firewall Rule	
Action	Block
Choose what to do with packets that match the criteria specified below. Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.	
Disabled	☐ Disable this rule Set this option to disable this rule without removing it from the list.
Interface	LAN
Choose the interface from which packets must come to match this rule.	
Address Family	IPv4
Select the Internet Protocol version this rule applies to.	
Protocol	TCP/UDP
Choose which IP protocol this rule should match.	
Source	
Source	☐ Invert match LAN net
Source Address /	
Display Advanced	
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any .	
Destination	
Destination	☐ Invert match any
Destination Address /	
Destination Port Range	From HTTP (80) To HTTP (80)
Custom Custom	
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.	
Extra Options	
Log	☒ Log packets that are handled by this rule Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).
Description	Block outbound HTTP (XSS protection)

Рисунок 46 – Правило «Блокировка исходящих HTTP-запросов»

Правило «Блокировка доступа к внутренним IP-адресам» показано на рисунке 47.

The screenshot shows the 'Edit Firewall Rule' configuration window. The 'Action' is set to 'Block'. The 'Interface' is 'LAN'. The 'Address Family' is 'IPv4'. The 'Protocol' is 'Any'. The 'Source' is 'LAN net'. The 'Destination' is 'Single host or alias' with the IP address '192.168.45.1'. The 'Log' checkbox is checked. The 'Description' is 'Block access to LAN PfSense'.

Edit Firewall Rule	
Action	Block
Choose what to do with packets that match the criteria specified below. Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.	
Disabled	☐ Disable this rule Set this option to disable this rule without removing it from the list.
Interface	LAN
Choose the interface from which packets must come to match this rule.	
Address Family	IPv4
Select the Internet Protocol version this rule applies to.	
Protocol	Any
Choose which IP protocol this rule should match.	
Source	
Source	☐ Invert match LAN net
Source Address /	
Destination	
Destination	☐ Invert match Single host or alias
192.168.45.1 /	
Extra Options	
Log	☒ Log packets that are handled by this rule Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).
Description	Block access to LAN PfSense

Рисунок 47 – Правило «Блокировка доступа к внутренним IP-адресам»

После добавления блокирующего правила для IP-адреса 192.168.45.1 (LAN). Создаётся аналогичное блокирующее правило для IP-адреса 192.168.100.50 (WAN).

Поле применения правил XSS была повторена. Во вкладке «Network» все запросы отображаются красным цветом, что свидетельствует о блокировке (рисунок 48).

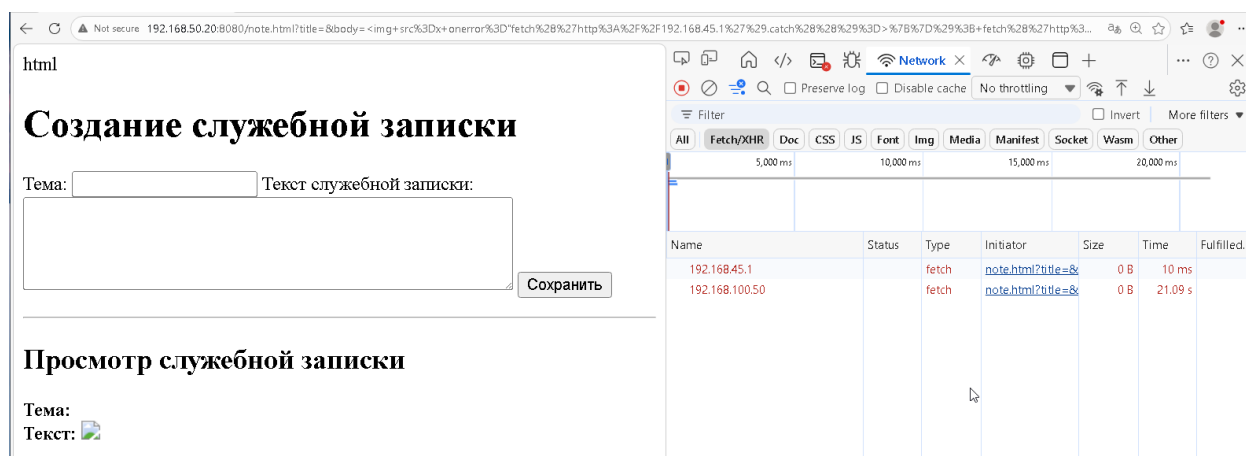


Рисунок 48 – Блокировка, после применения правил

Также в МЭ появились записи о блокировке. Логирование правил показано на рисунке 49.

✖	Mar 21 16:24:31	LAN	Block access to WAN PfSense (1774109901)	192.168.45.10:50669	192.168.100.50:80	TCP:S
✖	Mar 21 16:24:32	LAN	Block access to LAN PfSense (1774109819)	192.168.45.10:52704	192.168.45.1:53	UDP

Рисунок 49 – Логирование правил

Подводя итог проделанной работы, уязвимость проведение атаки типа межсайтового скриптинга (XSS) была устранена [24, 25].

ЗАКЛЮЧЕНИЕ

В ходе выполнения дипломного проекта на тему «Установка и настройка межсетевого экрана с функциями мониторинга для повышения информационной безопасности в корпоративной сети организации ООО «Авангард Бюро» в первом разделе проведено изучение потенциальных уязвимостей и угроз. Эти уязвимости и угрозы являются характерными для ИТ-инфраструктуры организации.

Рассмотрены нормативные документы и инструменты, применяемые для обеспечения сетевой безопасности. Особое внимание уделено анализу текущего состояния информационной защиты организации, а также классификации обрабатываемой информации.

На основе проведённого анализа, в третьем разделе реализованы мероприятия по усовершенствованию системы информационной безопасности: установлена и настроена программно-аппаратная платформа pfSense, обеспечивающая выполнение функций межсетевого экрана, базового сетевого мониторинга, а также логирование трафика. Pfsense интегрирована в локальную сеть организации ООО «Авангард Бюро» в качестве пограничного шлюза, что позволило централизовать контроль за входящим и исходящим трафиком и существенно повысить уровень защищённости информационной инфраструктуры.

Результаты, полученные в подразделах «настройка системы pfSense», а также «настройка межсетевого экрана pfSense» подтверждают, что внедрение pfSense дало положительный эффект в части выявления подозрительной сетевой активности, фильтрации нежелательного трафика и обеспечения отказоустойчивого доступа к внешним ресурсам. Тестирование системы показало стабильную работу, высокую эффективность фильтрации и удобство администрирования.

Таким образом, можно утверждать, что цель дипломного проекта достигнута, а все поставленные задачи успешно выполнены. Внедрение

pfSense в корпоративной сети организации ООО «Авангард Бюро» позволило создать надёжную основу для дальнейшего развития системы информационной безопасности предприятия. Разработанная архитектура сетевой защиты с использованием многофункционального межсетевого экрана обеспечила эффективную фильтрацию трафика, защиту от внешних угроз и возможность масштабирования системы.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Об информации, информационных технологиях и о защите информации: Федеральный закон от 27.07.2006 № 149-ФЗ [Электронный ресурс] Дата обновления: 12.2025. Доступ из системы «Консультант Плюс», дата обращения: 15.01.2025.
2. О персональных данных: Федеральный закон от 27.07.2006 № 152-ФЗ [Электронный ресурс]. Дата обновления: 06.2025. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.
3. Доктрина информационной безопасности Российской Федерации: Указ Президента РФ от 05.12.2016 № 646 [Электронный ресурс]. Дата обновления: 05.12.2016. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.
4. Перечень сведений конфиденциального характера: Указ Президента РФ от 13.07.2015 № 188 [Электронный ресурс]. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.
5. Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных: Постановление Правительства РФ от 01.11.2012 № 1119 [Электронный ресурс]. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.
6. ГОСТ Р ИСО/МЭК 27001-2021 «Системы менеджмента информационной безопасности. Требования» [Электронный ресурс]. Дата введения: 01.01.2022. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.
7. ГОСТ 20886-85 «Организация данных в системах обработки данных. Термины и определения» [Электронный ресурс]. Дата введения: 01.07.1986. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.
8. ГОСТ 15971-90 «Системы обработки информации. Термины и

определения» [Электронный ресурс]. Дата введения: 01.01.1992. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.

9. ГОСТ Р 50922-2006 «Защита информации. Основные термины и определения» [Электронный ресурс]. Дата введения: 01.02.2008. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.

10. ГОСТ Р 53114-2008 «Обеспечение информационной безопасности в организации. Основные термины и определения» [Электронный ресурс]. Дата введения: 01.10.2009. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.

11. ГОСТ Р 50739-95 «Защита от несанкционированного доступа к информации. Общие технические требования» [Электронный ресурс]. Дата введения: 01.01.1996. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.

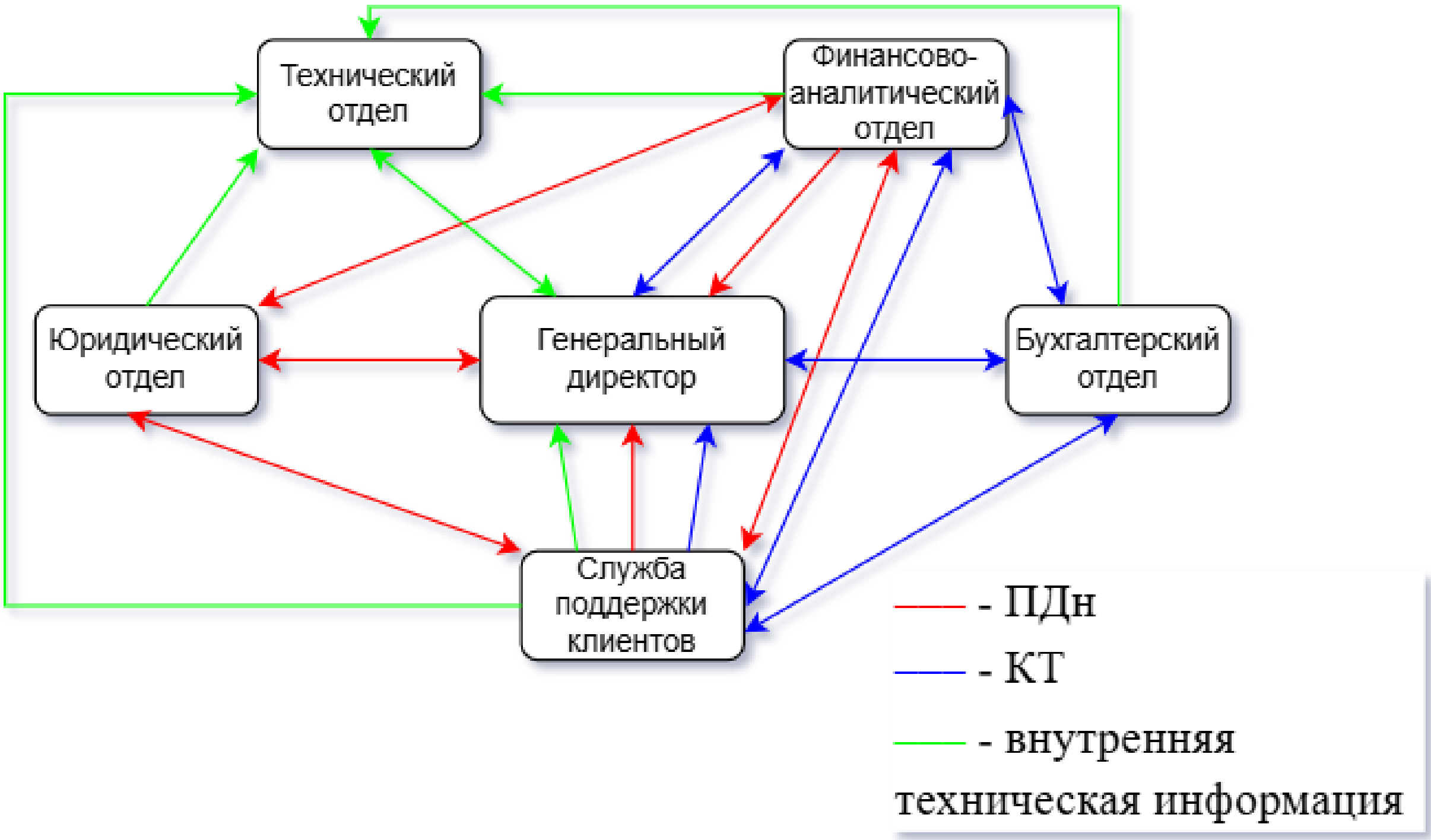
12. Методика оценки угроз безопасности информации: методический документ ФСТЭК России от 05.02.2021 [Электронный ресурс]. Доступ из системы «ФСТЭК России», дата обращения: 15.05.2025.

13. Базовая модель угроз безопасности персональных данных при их обработке в информационных системах персональных данных: ФСТЭК России от 15.02.2008 [Электронный ресурс]. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.

14. Об утверждении требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах: Приказ ФСТЭК России от 11.04.2025 № 117 [Электронный ресурс]. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.

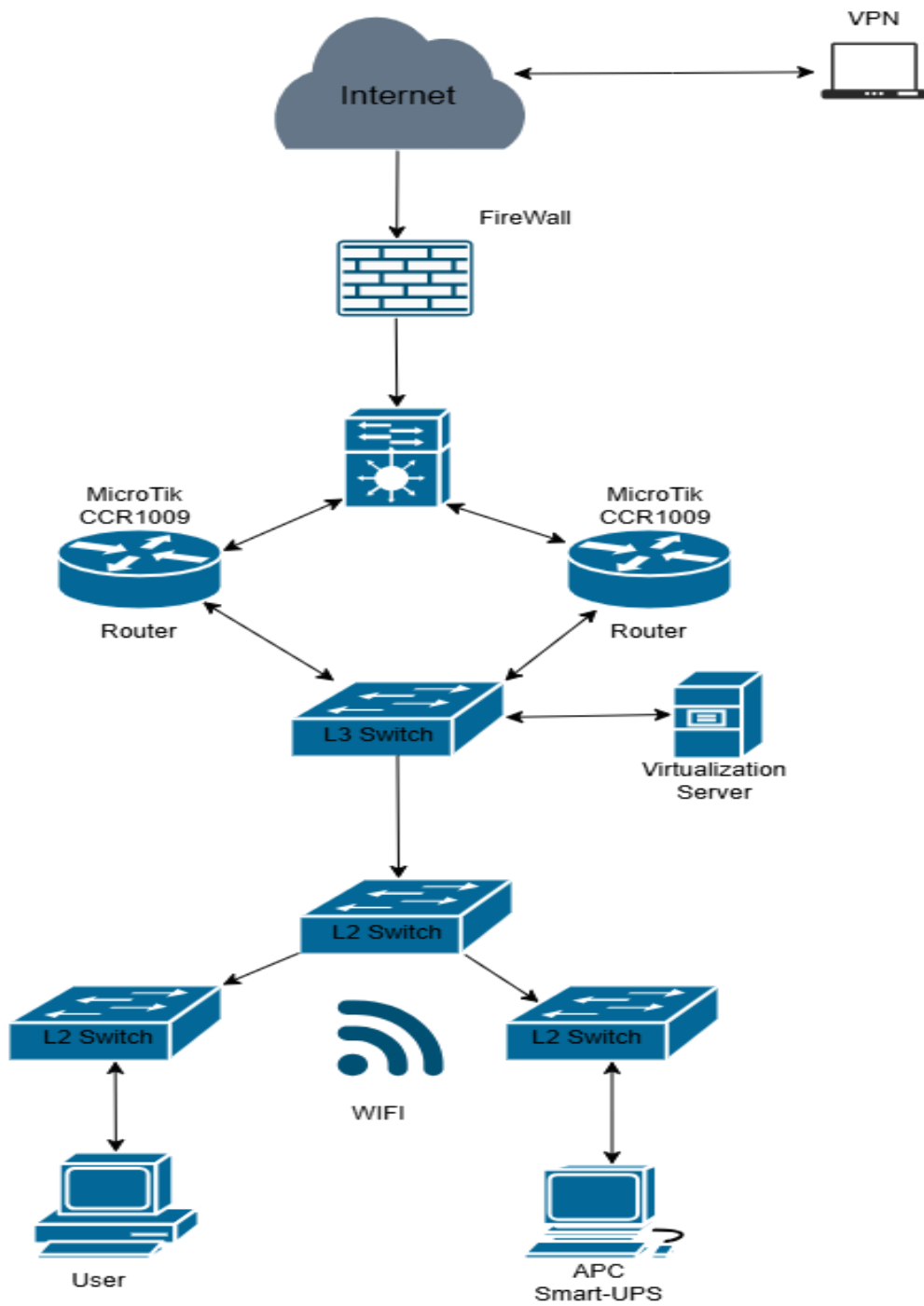
15. Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных: Приказ ФСТЭК России от 18.02.2013 № 21 [Электронный ресурс]. Доступ из системы «Консультант Плюс», дата обращения: 15.05.2025.

16. Защита от несанкционированного доступа к информации. Часть 1. Программное обеспечение средств защиты информации. Классификация по уровню контроля отсутствия недеklarированных возможностей: Руководящий документ ФСТЭК России от 04.06.1999 № 114 [Электронный ресурс]. Доступ из системы «ФСТЭК России», дата обращения: 15.05.2025.
17. Документация NETGATE pfSense [Электронный ресурс]. Доступ из системы «NETGATE», дата обращения: 15.05.2025.
18. Документация FireWall Kerio Control [Электронный ресурс]. Доступ из системы «Kerio», дата обращения: 15.05.2025.
19. Документация FireWall OPNsense [Электронный ресурс]. Доступ из системы «OPNsense», дата обращения: 15.05.2025.
20. Cisco. Руководство по настройке межсетевых экранов [Электронный ресурс]. Доступ из системы «Cisco», дата обращения: 12.05.2024.
21. Ростелеком. Технические требования к защите сетевой инфраструктуры [Электронный ресурс]. Доступ из системы «Ростелеком», дата обращения: 15.05.2024.
22. Shirey, R. RFC 4949. Internet Security Glossary, Version 2 [Электронный ресурс]. IETF, 2007. Дата обращения: 18.05.2024.
23. Безопасность информационных технологий: сборник научных трудов / под ред. А.Н. Платонова. – М.: Горячая линия–Телеком, 2022. – 320 с.
24. Конеев, И.Р.; Беляев, А.В. Защита информации в компьютерных системах и сетях. – 3-е изд. – М.: ДМК Пресс, 2021. – 416 с.
25. Материалы международной конференции «Информационная безопасность» (Москва, 15–17 ноября 2023 г.). – М.: Изд-во МГТУ им. Н.Э. Баумана, 2023. – 480 с.



Согласовано					
Инов. № подл.	Подп. и дата	Взам. Инов. №			

						ДП-10.02.04.ЩТКО-01-22.09.05.26.СЗ			
Изм.	Кол.у	Лист	№док	Под	Дата				
Разработал		Макасеев М.А.				Настройка политики фильтрации трафика с использованием межсетевого экрана открытого исходного кода	Стадия	Лист	Листов
Проверила		Журавлёва В.С.					ДП	1	3
						Схема организационной структуры и информационных потоков организации	РТУ МИРЭА		
Нормоконтроль		Герасин В.Ю.					Колледж программирования и кибербезопасности		



Согласовано					
Инов. № подл.	Подп. и дата	Взам. Инов. №			

						ДП-10.02.04.ЩТКО-01-22.09.05.26.С5					
Изм.	Кол.у	Лист	№док	Под	Дата						
Разработал		Макасеев М.А.				Настройка политики фильтрации трафика с использованием межсетевого экрана открытого исходного кода			Стадия	Лист	Листов
Проверила		Журавлёва В.С.							ДП	2	3
						Сетевая инфраструктура предприятия			РТУ МИРЭА		
									Колледж программирования и кибербезопасности		
Нормоконтроль		Герасин В.Ю.									

						ДП-10.02.04.ЩТКО-01-22.09.05.26.С1					
Изм.	Кол.у	Лист	№док	Под	Дата	Настройка политики фильтрации трафика с использованием межсетевого экрана открытого исходного кода			Стадия	Лист	Листов
Разработал		Макасеев М.А.							ДП	3	3
Проверила		Журавлёва В.С.				Модель угроз информационной безопасности			РТУ МИРЭА Колледж программирования и кибербезопасности		
Нормоконтроль		Герасин В.Ю.									

